



Cyber Protection Policy

for Small and Mid-Sized Businesses

Policy form HIC-CY-100 (10/26) · Declarations HIC-CY-DEC (10/26) · An admitted insurance policy

ISSUED TO Cedar Ridge Accounting Group, LLC	POLICY NUMBER HIC-CY-2026-004817	POLICY PERIOD Oct 15, 2026 – Oct 15, 2027	AGGREGATE LIMIT \$1,000,000
---	--	---	--

Suspect a cyberattack, breach or fraudulent payment?
Call before you do anything else. We answer 24 hours a day, 7 days a week.

1-800-555-0142

IMPORTANT: PARTS OF THIS POLICY ARE CLAIMS-MADE AND REPORTED. The liability coverages (Coverages I, J, K and L, and Coverage Q if purchased) apply only to **Claims** first made against you during the **Policy Period** and reported to us as Section V requires. **Claim Expenses** (defense costs) reduce the limits of liability and count toward the **Retention**. The first-party coverages apply to **Incidents** you first **Discover** during the **Policy Period**. Please read the entire policy carefully to understand what is and is not covered.

WHAT'S INSIDE

1. Important notices to policyholders
2. Declarations (HIC-CY-DEC)
3. What to do if something happens
4. Policy wording (HIC-CY-100), Sections I–VI
5. Terrorism disclosure (HIC-IL-TRIA)

YOUR POLICY AT A GLANCE

1. \$1,000,000 for all coverages combined
2. \$5,000 retention per incident, after security credit
3. First 72 hours of incident response at no cost to you
4. 12 core coverages plus 2 optional coverages purchased

Important Notices to Policyholders

Please read these notices. They explain how this policy works and what it does not do. They do not change or add to the coverage in the policy. If a notice and the policy wording differ, the policy wording controls.

1 Some coverages are claims-made and reported

Coverages I (Network Security and Privacy Liability), J (Regulatory Defense and Penalties), K (PCI Fines and Assessments), L (Media Liability) and, if purchased, Q (Website Tracking Liability) cover only **Claims** first made against you during the **Policy Period** and reported to us within the deadlines in Section V. A **Claim** first made after this policy ends is not covered unless an **Extended Reporting Period** applies. If you replace this policy, make sure the new policy covers earlier events (see “Retroactive Date” in Item 8 of the Declarations).

2 Defense costs reduce your limits

Money we spend on lawyers, experts and other **Claim Expenses** is part of, and reduces, the limits of liability. It also counts toward your **Retention**. Once the limits are used up, we have no further duty to defend or pay.

3 How to read this policy

We have tried to write this policy in plain English. Words in **bold** have the meanings given in Section II, Definitions. The coverage letters (A through R) are the same in the Declarations and the policy wording. Headings and the shaded “In short” notes help you find your way. They are not part of the contract terms and do not limit or expand coverage.

4 What this policy does not do

This policy is not a guarantee that you will not suffer a cyberattack, and it does not replace good security. It does not cover every cyber-related loss. In particular, it is not a professional liability (errors and omissions) policy, a crime or fidelity policy for employee theft, or a property policy for physical damage. You may need those policies as well. Ask your insurance adviser if you are unsure.

5 Ransom payments and sanctions

We may pay or reimburse an extortion payment only where the law allows it, only with our prior written consent, and only after the checks described in Section V. We cannot make or reimburse any payment that would violate U.S. or other applicable economic sanctions. U.S. Department of the Treasury guidance encourages victims to report ransomware attacks to law enforcement promptly. We will help you do so.

6 Terrorism coverage

Losses from certified acts of terrorism are covered to the extent this policy otherwise covers them. The required federal disclosure is included at the end of this packet (form HIC-IL-TRIA).

7 Your privacy

We collect information about your business, and about individuals connected to it, to underwrite this policy, handle claims and meet legal obligations. We do not sell this information. We share it only with service providers, reinsurers, regulators and others as the law permits or requires. You may ask what information we hold about you by writing to privacy@harborlineinsurance.com or to our home office shown in the Declarations.

8 Admitted insurer and guaranty fund protection

Harborline Insurance Company is licensed (“admitted”) to write this insurance in Colorado, and this policy form is filed with the Colorado Division of Insurance. If an admitted insurer becomes insolvent, covered claims may be paid by the state insurance guaranty association, subject to its limits and rules.

9 Questions and complaints

If you have a question about your coverage or a claim, call us first at 1-800-555-0142. If we cannot resolve your concern, you may contact the Colorado Division of Insurance (doi.colorado.gov).

Specimen disclaimer. This document is a specimen policy prepared to illustrate policy design. Harborline Insurance Company is fictional. The document is not an offer to sell insurance, has not been filed with or approved by any regulator, and is not legal advice. Any resemblance to an actual insurer, policyholder or person is coincidental.



HARBORLINE
INSURANCE
COMPANY

Policy Declarations

Cyber Protection Policy for Small and Mid-Sized Businesses
Form HIC-CY-DEC (10/26)

SPECIMEN — for illustration only. Harborline Insurance Company, its phone number and web addresses are fictional.

IMPORTANT NOTICES — PLEASE READ

- Your liability coverages (I through L, and Q if purchased) are **claims-made and reported**. They cover claims first made against you during the policy period and reported to us as this policy requires.
- **Defense costs reduce your limits**. Money spent on lawyers counts toward your limit and your retention.
- This page is a summary. The full policy wording controls. Words in bold in the policy have special meanings, defined in the Definitions section.

Policy number	HIC-CY-2026-004817	New or renewal	New
Producer	Direct (no broker)	Issuing company	Harborline Insurance Company, an admitted insurer Home office: 100 Harborline Plaza, Denver, CO 80202

ITEMS 1-5 · INSURED, PERIOD, PREMIUM, LIMITS, RETENTION

Item 1. Named insured	Cedar Ridge Accounting Group, LLC 1450 Market Street, Suite 600, Denver, CO 80202 Website and email domains: cedarridgecpa.com		
Item 2. Policy period	From October 15, 2026 to October 15, 2027 , both dates at 12:01 a.m. local time at the address in Item 1.		
Item 3. Premium	Base annual premium		\$6,120
	Security credit (see Item 7)		-\$612
	Taxes and fees		\$0
	Total due		\$5,508
Item 4. Limits of liability	Policy aggregate limit: \$1,000,000 — the most we will pay for all coverages combined during the policy period, including defense costs. Incident response services: the first 72 hours after you report are provided <i>in addition to</i> the aggregate limit, with no retention.		
Item 5. Retention (your deductible)	Standard retention for revenue \$5M–\$25M: \$10,000 each incident Your retention after security credit: \$5,000 each incident One retention per incident. If one incident triggers several coverages, you pay only the single largest retention that applies.		

ITEM 6 · COVERAGE SCHEDULE

Core coverages are always included. Optional coverages apply only where marked **Yes**. Coverage letters match the insuring agreements in Section I of the policy. Every limit is part of, not in addition to, the \$1,000,000 policy aggregate limit (except Coverage A).

	PART 1 · CORE COVERAGE	WHAT IT PAYS FOR, IN PLAIN ENGLISH	LIMIT	RETENTION
A	Incident Response Services	24/7 hotline, breach coach and first-response forensics for the first 72 hours	Included (outside limit)	\$0
B	Breach Response Costs	Forensics, legal advice, notification letters, call center, credit monitoring, crisis PR	\$1,000,000	\$5,000
C	Cyber Extortion and Ransomware	Expert negotiators and, where legally allowed, ransom payments	\$1,000,000	\$5,000
D	Business Interruption	Lost income and extra costs while your systems are down after a cyberattack	\$1,000,000	8-hour waiting period
E	Dependent Business Interruption	The same, when an attack on your IT or cloud provider takes you offline	\$500,000	8-hour waiting period
F	Data and System Restoration	Restoring data and software, and removing malware	\$1,000,000	\$5,000
G	Security Improvement Costs	Security upgrades our incident team recommends after a covered attack	\$25,000	None
H	Social Engineering and Funds Transfer Fraud	Money lost when you are tricked or hacked into sending payments, including by deepfakes	\$250,000	\$5,000 (\$2,500 if reported to us and your bank within 72 hours)
I	Network Security and Privacy Liability	Lawsuits from customers or others after a breach or privacy violation	\$1,000,000	\$5,000
J	Regulatory Defense and Penalties	Government investigations, and fines where insurable by law	\$1,000,000	\$5,000
K	PCI Fines and Assessments	Card brand fines and assessments after a payment card breach	\$250,000	\$5,000
L	Media Liability	Claims over your website or social media content (defamation, copyright)	\$1,000,000	\$5,000

Business interruption period of restoration: up to 180 days from when the outage begins (Coverages D, E and M).

	PART 2 · OPTIONAL COVERAGE	WHAT IT PAYS FOR	PURCHASED?	LIMIT	RETENTION
M	System Failure Business Interruption	Lost income from non-malicious outages, like a failed software update	No	—	—
N	Computer Replacement (Bricking)	Replacing hardware made unusable by an attack	Yes	\$100,000	\$5,000
O	Reputational Harm	Lost profit when news of a breach drives customers away	No	—	—
P	Cryptojacking and Telecom Fraud	Unauthorized use of your computing power or phone lines	Yes	\$50,000	\$5,000
Q	Website Tracking Liability	Lawsuits over website pixels and cookies (e.g., California's CIPA)	No	—	—
R	Increased Fraud Limit	Raises the Coverage H limit to \$500,000	No	—	—

ITEMS 7-12 · CREDITS, DATES, REPORTING AND FORMS			
Item 7. Security credits (based on your application)	SECURITY CONTROL	VERIFIED?	WHAT YOU EARNED
	Multi-factor authentication (MFA) on email, remote access and admin accounts, plus EDR on all devices	Yes	Retention cut from \$10,000 to \$5,000, plus a 10% premium credit
	Offline or immutable backups, with restoration tested in the last 12 months	Yes	No ransomware coinsurance (otherwise you pay 20% of ransomware losses)
	Callback verification for all payment and bank-detail changes	Yes	Coverage H at the full \$250,000 (otherwise \$100,000)
	24/7 managed detection and response (MDR)	No	Not earned — would cut the business interruption waiting period from 8 to 4 hours
Section IV.G of the policy explains what happens if a credited control is not in place when an incident occurs.			
Item 8. Claims-made dates	Retroactive date: Full prior acts (no date restriction) Continuity date: October 15, 2026 — we do not cover problems your executives knew about before this date		
Item 9. Extended reporting period	Automatic: 60 days after the policy ends Optional: 12 months for 75% of the annual premium, or 24 months for 125% Not available if we cancel for non-payment or fraud.		
Item 10. How to report an incident (24/7)	Hotline 1-800-555-0142 Email incidents@harborlineinsurance.com Online harborlineinsurance.com/report Report as soon as possible. Never delay a notice that the law requires you to make.		
Item 11. Choice of law	Colorado		
Item 12. Forms and endorsements	FORM	TITLE	
	HIC-CY-DEC (10/26)	Declarations	
	HIC-CY-100 (10/26)	Cyber Protection Policy	
	HIC-CY-APP (10/26)	Application (attached)	
	HIC-CY-CO (10/26)	Colorado Amendatory Endorsement*	
	HIC-IL-TRIA (10/26)	Terrorism Risk Insurance Act Disclosure	
*State amendatory endorsements are filed separately with the state regulator and are not reproduced in this specimen.			

These Declarations, the policy form, the Application and any endorsements listed in Item 12 together make up your policy.

Eleanor Voss
 President, Harborline Insurance Company

Marcus Hale
 Secretary, Harborline Insurance Company

October 15, 2026
 Date issued

WHAT TO DO IF SOMETHING HAPPENS

Keep this page where your team can find it. Speed matters: most of the cost of an attack is decided in the first few hours.

- 1

Call the hotline first: 1-800-555-0142

Our breach coach answers 24/7. The first 72 hours of incident response are free (Coverage A) and do not reduce your limit. If you are unsure whether something counts, call anyway. Suspected incidents are covered.
- 2

Don't pay a ransom, negotiate or admit fault before talking to us

Paying or negotiating without our consent can break the law and can void coverage for that payment. Don't reply to the attacker. Don't tell customers or others that you are at fault.
- 3

Preserve evidence

Disconnect affected machines from the network, but don't switch them off, wipe or rebuild them until our forensics team says so. Keep emails, logs and ransom notes.
- 4

Sent money to a fraudster? Call your bank, then us, within 72 hours

Ask your bank to recall the transfer and file a report at ic3.gov. Reporting to your bank and to us within 72 hours halves your Coverage H retention to \$2,500, and fast reporting gives the best chance of recovering the money.
- 5

We assemble your response team

Lawyers, forensic investigators, negotiators and notification vendors from our panel start work without further paperwork. You may ask to use your own providers. See Section V.C of the policy.
- 6

Make legally required notices on time

Many state laws, including Colorado's, require you to notify affected people within 30 days. You never need our permission to meet a legal deadline, and we will never deny coverage because you did.

YOUR RESPONSE CONTACTS — FILL IN AND KEEP WITH YOUR INCIDENT RESPONSE PLAN	
Harborline 24/7 hotline	1-800-555-0142 · incidents@harborlineinsurance.com
Your policy number	HIC-CY-2026-004817
Internal response lead	Dana Whitfield, Managing Partner · 303-555-0187
IT provider (MSP)	Summit Peak Technology Partners · 24/7 line 303-555-0164
Bank fraud line (wire recalls)	Use the number printed on your bank card or statement, not one from an email
Law enforcement	FBI Internet Crime Complaint Center: ic3.gov

Policy Contents

Important notices to policyholders	2	Core coverages	8
Declarations	3	A Incident Response Services	8
What to do if something happens	6	B Breach Response Costs	8
Policy form HIC-CY-100	8	C Cyber Extortion and Ransomware	8
Section I · What We Cover	8	D Business Interruption	9
Section II · Definitions	11	E Dependent Business Interruption	9
Section III · What We Do Not Cover	18	F Data and System Restoration	9
Section IV · Limits, Retention and Coinsurance	20	G Security Improvement Costs	9
Section V · When Something Happens	22	H Social Engineering and Funds Transfer Fraud	9
Section VI · General Conditions	24	I Network Security and Privacy Liability	10
Terrorism disclosure HIC-IL-TRIA	28	J Regulatory Defense and Penalties	10
		K PCI Fines and Assessments	10
		L Media Liability	10
		Optional coverages	10
		M System Failure Business Interruption	10
		N Computer Replacement (Bricking)	10
		O Reputational Harm	11
		P Cryptojacking and Telecom Fraud	11
		Q Website Tracking Liability	11
		R Increased Fraud Limit	11

HOW TO FIND WHAT YOU NEED

What is covered?	Section I, Coverages A–R. The letters match Item 6 of the Declarations.
What do the bold words mean?	Section II, in alphabetical order.
What is not covered?	Section III. Part A applies to every coverage; Part B to specific coverages.
How much will Harborline pay, and what do I pay?	Section IV, together with Items 4–7 of the Declarations.
What do I do when something happens?	Section V, and the one-page guide after the Declarations.
What other rules apply?	Section VI (cancellation, extended reporting, sanctions and more).

Cyber Protection Policy

for Small and Mid-Sized Businesses · Form HIC-CY-100 (10/26)

This policy is a contract between you and us. In return for your premium, and relying on the statements in your **Application**, we agree to provide the coverage described below, subject to the Declarations and all the terms of this policy.

Throughout this policy, “you” and “your” mean the **Insured Organization**. “We,” “us” and “our” mean Harborline Insurance Company. Other words in **bold** have the meanings given in Section II. The coverage letters A through R are the same as in Item 6 of the Declarations.

SECTION I WHAT WE COVER

How coverage is triggered

1. **First-party coverages** (Coverages B–H, M, N, O, P and R) apply to an **Incident** that you first **Discover** during the **Policy Period** and report to us as Section V.A requires.
2. **Liability coverages** (Coverages I–L and Q) apply to a **Claim** first made against an **Insured** during the **Policy Period** or any **Extended Reporting Period**, and reported to us as Section V.A requires, for a **Wrongful Act, Security Failure** or **Privacy Event** that first took place on or after the **Retroactive Date**, if any.
Coverage A has its own trigger, described in Coverage A.
3. Every payment is subject to the limits, **Retention**, **Waiting Period** and coinsurance terms in Section IV and the Declarations.
4. Optional coverages (Part 2) apply only if Item 6 of the Declarations shows them as purchased.

PART 1 — CORE COVERAGES

A Incident Response Services

IN SHORT One call to our hotline gets you a breach lawyer and a forensic team. The first 72 hours cost you nothing and do not reduce your limit.

If you report an actual or suspected **Incident** to our **Hotline** during the **Policy Period**, we will provide **Incident Response Services** through our **Panel Providers** for the first 72 hours after your report. We will provide these services even if it later turns out that no **Incident** occurred.

Incident Response Services are provided in addition to the Policy Aggregate Limit, and no **Retention** applies. Services after the first 72 hours are covered under the coverage that applies to them (for example, Coverage B, C or F), subject to that coverage's limit and the **Retention**.

B Breach Response Costs

IN SHORT We pay to investigate a breach, meet your legal duties to notify people, and protect the people affected.

We will pay **Breach Response Costs** that you incur because of an actual or reasonably suspected **Security Failure** or **Privacy Event** that you first **Discover** during the **Policy Period**.

C Cyber Extortion and Ransomware

IN SHORT If criminals threaten your systems or data and demand payment, we pay experts to respond and, where the law allows, the payment itself.

We will pay **Extortion Costs** that you incur to respond to a **Cyber Extortion Threat** that you first **Discover** during the **Policy Period**. An **Extortion Payment** requires our prior written consent and the steps in Section V.F.

D Business Interruption

IN SHORT If a cyberattack takes your systems down for more than 8 hours, we pay the income you lose and the extra costs of keeping the business running, for up to 180 days.

We will pay **Business Interruption Loss** that you incur during the **Period of Restoration** as a direct result of an **Interruption** of your **Computer System** caused by a **Security Failure** that you first **Discover** during the **Policy Period**.

We pay only if the **Interruption** lasts longer than the **Waiting Period**, and only for **Business Interruption Loss** incurred after the **Waiting Period** ends.

E Dependent Business Interruption

IN SHORT The same protection as Coverage D when the attack hits an IT or cloud provider you rely on, rather than your own systems.

We will pay **Business Interruption Loss** that you incur during the **Period of Restoration** as a direct result of an **Interruption** of a **Dependent Business's** computer systems caused by a **Security Failure** of those systems that you first **Discover** during the **Policy Period**.

We pay only if the **Interruption** lasts longer than the **Waiting Period**, and only for **Business Interruption Loss** incurred after the **Waiting Period** ends.

F Data and System Restoration

IN SHORT We pay to get your data and software back to the way they were before an attack, and to remove malware.

We will pay **Restoration Costs** that you incur because of a **Security Failure** that you first **Discover** during the **Policy Period**.

G Security Improvement Costs

IN SHORT After a covered attack, we help pay for the fixes our experts recommend so it does not happen again.

If an **Incident** causes **Loss** covered under Coverage B, C, D or F (whether or not that **Loss** exceeds the **Retention**), we will also pay **Security Improvement Costs** that you incur within 90 days after that **Incident** is contained, up to the limit shown for Coverage G in Item 6 of the Declarations. No separate **Retention** applies to this coverage.

H Social Engineering and Funds Transfer Fraud

IN SHORT If you are tricked into sending money to a criminal, or a criminal breaks into your accounts and moves money, we reimburse you. Verifying payment changes by phone keeps your full limit.

1. We will pay your **Direct Financial Loss** resulting from **Funds Transfer Fraud**, **Social Engineering Fraud** or **Invoice Manipulation** that you first **Discover** during the **Policy Period**.
2. **Callback verification.** If **Social Engineering Fraud** involves an instruction to pay a new payee, or to change the bank account or payment details for an existing payee, the most we will pay for that **Incident** is \$100,000 unless you performed **Callback Verification** before the transfer. This amount is part of, not in addition to, the Coverage H limit.

3. If Item 7 of the Declarations shows that the callback verification credit was not earned, the Coverage H limit is \$100,000.
4. If you report the **Incident** to us, and to your financial institution, within 72 hours after you first **Discover** it, the **Retention** is halved as Section IV.D.4 describes.

I Network Security and Privacy Liability

IN SHORT If customers, employees or business partners sue you after a breach or privacy failure, we defend you and pay settlements and judgments.

We will pay **Damages** and **Claim Expenses** that an **Insured** becomes legally obligated to pay because of a **Claim** alleging a **Security Wrongful Act** or **Privacy Wrongful Act**.

J Regulatory Defense and Penalties

IN SHORT If a regulator investigates you after a breach, we pay your lawyers and, where the law allows, the fines.

We will pay **Claim Expenses** and **Regulatory Penalties** that an **Insured** becomes legally obligated to pay because of a **Regulatory Proceeding** arising from a **Security Failure** or **Privacy Event**.

K PCI Fines and Assessments

IN SHORT If card data is breached and the card brands or your bank bill you for fines and fraud costs, we pay them.

We will pay **PCI Fines and Assessments** and **Claim Expenses** that an **Insured** becomes legally obligated to pay because of a **PCI Claim** arising from a **Security Failure** or **Privacy Event** involving **Payment Card Data**.

L Media Liability

IN SHORT If someone sues you over content on your website, social media or marketing (for example for defamation or copyright infringement), we defend you and pay the damages.

We will pay **Damages** and **Claim Expenses** that an **Insured** becomes legally obligated to pay because of a **Claim** alleging a **Media Wrongful Act**.

PART 2 — OPTIONAL COVERAGES (ONLY IF SHOWN AS PURCHASED IN ITEM 6)

M System Failure Business Interruption **OPTIONAL**

IN SHORT Extends Coverage D to outages that are not caused by an attack, such as a failed software update or an IT mistake.

We will pay **Business Interruption Loss** that you incur during the **Period of Restoration** as a direct result of an **Interruption** of your **Computer System** caused by a **System Failure** that you first **Discover** during the **Policy Period**. We pay only if the **Interruption** lasts longer than the **Waiting Period**, and only for **Business Interruption Loss** incurred after the **Waiting Period** ends.

N Computer Replacement (Bricking) **OPTIONAL**

IN SHORT If an attack leaves laptops, servers or network equipment permanently unusable, we pay to replace them.

We will pay the reasonable cost to replace **Hardware** that a **Security Failure**, first **Discovered** during the **Policy Period**, has made unusable for its intended purpose, if the **Hardware** cannot be restored by reinstalling or reconfiguring its software or firmware, or if replacing it costs less than restoring it.

We will pay for replacement **Hardware** of like kind, quality and function. If that is no longer available, we will pay for the closest current equivalent, even if it performs better. Coverage N does not apply to **Hardware** that is lost or stolen.

O **Reputational Harm** OPTIONAL

IN SHORT If news of a breach drives customers away, we pay the profit you lose for up to 180 days.

We will pay **Reputational Harm Loss** that you incur during the 180 days after an **Adverse Publication** about a **Security Failure** or **Privacy Event** that you first **Discover** during the **Policy Period**. The **Adverse Publication** must first be published during the **Policy Period** or within 60 days after it ends.

P **Cryptojacking and Telecom Fraud** OPTIONAL

IN SHORT If criminals use your computers or cloud accounts to mine cryptocurrency, or hijack your phone system, we pay the resulting bills.

We will pay the following amounts, if the **Cryptojacking** or **Telecom Fraud** is first **Discovered** during the **Policy Period**:

1. additional charges for electricity, cloud computing or other metered services that you incur because of **Cryptojacking**; and
2. charges from your telephone or telecommunications provider that you are legally obligated to pay because of **Telecom Fraud**.

Q **Website Tracking Liability** OPTIONAL

IN SHORT Covers lawsuits claiming that pixels, cookies or similar tools on your website collected or shared visitor data unlawfully.

We will pay **Damages** and **Claim Expenses** that an **Insured** becomes legally obligated to pay because of a **Claim** alleging a **Tracking Wrongful Act**. When this coverage applies, Exclusion III.A.15(b) does not apply to that **Claim**.

R **Increased Fraud Limit** OPTIONAL

IN SHORT Doubles the social engineering and funds transfer fraud limit to \$500,000.

The Coverage H limit is increased to \$500,000. The increased limit remains part of the Policy Aggregate Limit and remains subject to Coverage H, paragraph 2, and Section IV.G.1(c). Coverage R is available only if Item 7 of the Declarations shows that the callback verification credit was earned.

SECTION II DEFINITIONS

In this policy, words and phrases in **bold** have the meanings below. The singular includes the plural, and the plural includes the singular. “Including” means “including but not limited to.”

1. “**Adverse Publication**” means a report or communication to the public, by a news outlet or on a social media platform, by someone other than an **Insured**, that discloses a **Security Failure** or **Privacy Event**.
2. “**Application**” means the signed application for this policy (form HIC-CY-APP) and all information, attachments and statements you gave us with it or during underwriting. It does not include the results of any external security scan that we run ourselves.

3. **“Bodily Injury”** means physical injury, sickness, disease or death of a person, and any mental anguish or emotional distress resulting from it.
4. **“Breach Response Costs”** means the following reasonable and necessary costs, incurred within 12 months after you first **Discover** the **Security Failure** or **Privacy Event** (or longer if a law requires the service):
 - (a) forensic investigation to find the cause and scope of the event, contain it, and determine whether **Personal Information** or **Confidential Information** was affected;
 - (b) legal services to advise you on your response and to determine and meet your notification obligations under **Privacy Law**;
 - (c) notifying affected individuals, regulators, payment card companies and others as required by law, or as we agree will reduce **Loss**;
 - (d) a call center to answer questions from notified individuals;
 - (e) credit monitoring, identity monitoring and identity restoration services for affected individuals for 12 months, or longer if a law requires it; and
 - (f) public relations and crisis communications services to limit harm to your reputation.
5. **“Business Interruption Loss”** means **Income Loss** and **Extra Expense**. It also includes reasonable fees of a forensic accountant, approved by us, to calculate your **Income Loss** and **Extra Expense**.
6. **“Callback Verification”** means confirming a payment instruction, or a change to a payee's bank account or payment details, by contacting the person or organization that supposedly made the request, using a telephone number or other contact method that was on file before the request was received or that you obtained independently. A contact method supplied in the request itself does not count. You must keep a record of the verification.
7. **“Claim”** means any of the following made against an **Insured**:
 - (a) a written demand for money, services or other relief;
 - (b) a civil lawsuit, started by the service of a complaint or similar document;
 - (c) an arbitration, mediation or other alternative dispute resolution proceeding;
 - (d) a **Regulatory Proceeding**;
 - (e) a **PCI Claim**; or
 - (f) a written request to toll or waive a statute of limitations.

A **Claim** is first made when an **Executive** first receives it. A criminal proceeding is not a **Claim**.

8. **“Claim Expenses”** means reasonable and necessary fees and costs, including those of lawyers and experts, incurred by us, or by an **Insured** with our consent, to investigate, defend, settle or appeal a **Claim**, including the premium for an appeal bond (but not the obligation to provide one). It does not include salaries, wages or overhead of any **Insured** or of us.
9. **“Computer System”** means computers and related hardware, software, firmware, networks, mobile devices, connected devices, data storage and backup facilities, and cloud computing environments, that are:
 - (a) owned, leased or operated by the **Insured Organization**; or
 - (b) owned by an employee and used, with your permission, to conduct your business.

For all coverages other than Coverages D, E, M and N, **Computer System** also includes systems operated for you by a third party under a written contract (for example, hosted email, a hosted application or a data storage service).

10. **“Confidential Information”** means non-public information of a third party, other than **Personal Information**, that is in the care, custody or control of an **Insured** (or of a third party on your behalf) and that you are legally or contractually required to keep confidential.
11. **“Continuity Date”** means the date shown in Item 8 of the Declarations.
12. **“Cryptjacking”** means the unauthorized use of your **Computer System**, including your cloud computing accounts, to mine digital currency.
13. **“Cyber Extortion Threat”** means a threat, made by someone other than an **Executive**, to do any of the following unless paid money, digital currency or other property: release, sell, destroy, corrupt or keep encrypted your **Data** or **Personal Information**; introduce malicious code into your **Computer System**; carry out a denial-of-service attack against your **Computer System**; or continue an attack already under way. It includes a **Ransomware Event**.
14. **“Damages”** means compensatory damages, judgments, settlements, pre-judgment and post-judgment interest, and awards of the claimant's legal costs, that an **Insured** is legally obligated to pay. It includes punitive, exemplary and multiplied damages where insurable under the law of the applicable jurisdiction that most favors coverage. It does not include:
 - (a) fines, penalties, taxes or sanctions, except as covered under Coverages J and K;
 - (b) the return or restitution of fees, profits or other amounts paid to an **Insured**;
 - (c) the cost of complying with an injunction or other non-monetary relief;
 - (d) royalties or licensing fees; or
 - (e) liquidated damages, to the extent they exceed the amount the **Insured** would have owed without the agreement.
15. **“Data”** means information that is stored electronically, including software, programs and electronic records.
16. **“Deepfake”** means audio, video, images or text created or altered using artificial intelligence or similar technology so that it appears to come from a real person or organization.
17. **“Dependent Business”** means an organization, other than an **Insured Organization**, that provides you, under a written contract, with information technology services, including cloud computing (infrastructure, platform or software as a service), data hosting, managed IT or security services, or business software that you access online. It does not include a provider of electricity, gas, water, internet backbone, telecommunications or satellite services.
18. **“Direct Financial Loss”** means the amount of **Money** or **Securities** lost, or for **Invoice Manipulation** the amount your customer paid to the criminal that you are unable to collect, less any amount recovered. It does not include interest, lost profits, fees, or any other indirect or consequential loss.
19. **“Discover”** (and **“Discovers,” “Discovered”** or **“Discovery”**) means the moment an **Executive** first becomes aware of facts that would cause a reasonable person to believe that an **Incident** has occurred or is occurring, even if the amount or details of the **Loss** are not yet known.
20. **“Executive”** means any owner, partner, principal, officer, director, member or manager of an **Insured Organization**, and any employee responsible for its information technology or information security. For Definition 19, Exclusion III.A.2 and Section V.A only, it also includes an outsourced provider acting as the person responsible for information technology or information security. That provider is not an **Insured** because of this definition.
21. **“Extended Reporting Period”** means the period described in Section VI.D.

22. **“Extortion Costs”** means:
- (a) fees of **Panel Providers** or other experts we approve to assess, negotiate and respond to a **Cyber Extortion Threat**;
 - (b) an **Extortion Payment**; and
 - (c) reasonable costs to buy, transfer or convert digital currency to make an **Extortion Payment**.
23. **“Extortion Payment”** means money, digital currency or other property paid to end a **Cyber Extortion Threat**, valued at the time of payment.
24. **“Extra Expense”** means reasonable and necessary costs, above your normal operating costs, that you incur to avoid or reduce an **Interruption** and to keep your business operating, such as overtime, temporary staff, rented equipment and outsourced services. It does not include **Restoration Costs**, **Security Improvement Costs** or the cost of improving any system.
25. **“Funds Transfer Fraud”** means a fraudulent instruction, sent to a financial institution by someone other than an **Insured** and without your knowledge or consent, that directs the institution to transfer, pay or deliver **Money** or **Securities** from an account held by the **Insured Organization**. It includes an instruction made through unauthorized access to your **Computer System** or online banking credentials.
26. **“Hardware”** means the physical components of your **Computer System** that the **Insured Organization** owns or leases, such as servers, desktop and laptop computers, network equipment and mobile devices.
27. **“Hotline”** means the incident reporting channels shown in Item 10 of the Declarations.
28. **“Incident”** means a **Security Failure**, **Privacy Event**, **Cyber Extortion Threat**, **Funds Transfer Fraud**, **Social Engineering Fraud**, **Invoice Manipulation**, **System Failure**, **Cryptojacking** or **Telecom Fraud**. **Related Incidents** are one **Incident**.
29. **“Incident Response Services”** means the following services from **Panel Providers**:
- (a) a breach coach (a lawyer experienced in cyber incidents) to direct the response and protect legal privilege;
 - (b) initial forensic triage, including remote investigation and containment;
 - (c) an initial assessment of any **Cyber Extortion Threat**; and
 - (d) initial advice on your legal notification obligations.
30. **“Income Loss”** means the net profit before taxes that you would have earned if the **Interruption** had not occurred, minus the net profit before taxes you actually earned, plus your normal operating expenses (including payroll) that continue during the **Interruption**. It is calculated as Section V.I describes.
31. **“Insured”** means:
- (a) the **Insured Organization**;
 - (b) any past, present or future **Executive**, employee, temporary or leased worker, intern or volunteer of the **Insured Organization**, but only while acting on its behalf;
 - (c) any natural person who is an independent contractor of the **Insured Organization**, but only while performing work for it under its direction;
 - (d) any person or organization that the **Insured Organization** agreed in a written contract to add as an insured, but only for its liability arising from a **Wrongful Act** of an **Insured** described in (a) to (c); and
 - (e) the spouse, domestic partner, estate, heirs or legal representatives of anyone in (b), but only for a **Claim** arising from that person's acts as an **Insured**.

32. **“Insured Organization”** means the **Named Insured** and any **Subsidiary**.
33. **“Interruption”** means an actual and measurable interruption, suspension, failure or slowdown of a computer system. It includes a reasonable shutdown of your **Computer System** that you make, or that we or a **Panel Provider** recommend, to contain or limit a **Security Failure**.
34. **“Invoice Manipulation”** means the sending of fraudulent payment instructions to one of your customers or clients, by a third party impersonating you, as a direct result of a **Security Failure** of your **Computer System**, which causes the customer or client to pay the third party money that it owed you for goods or services you had already provided.
35. **“Loss”** means any amount payable under a coverage in Section I, including **Breach Response Costs, Business Interruption Loss, Claim Expenses, Damages, Direct Financial Loss, Extortion Costs, PCI Fines and Assessments, Regulatory Penalties, Reputational Harm Loss, Restoration Costs, Security Improvement Costs, Hardware** replacement costs under Coverage N and charges under Coverage P.
36. **“Media Content”** means text, images, audio, video, software code or other content that an **Insured** publishes or distributes, in any form or medium, including on your website, social media accounts, emails, newsletters and advertising.
37. **“Media Wrongful Act”** means any of the following committed by an **Insured** in **Media Content**: defamation, libel, slander, trade libel or product disparagement; invasion of privacy, false light, or misappropriation of a person's name or likeness; infringement of copyright, trademark, trade dress, domain name, title or slogan; plagiarism or piracy; or negligence in publishing content.
38. **“Money”** means currency, coins, bank notes and funds on deposit. It does not include digital currency.
39. **“Named Insured”** means the organization shown in Item 1 of the Declarations.
40. **“Panel Provider”** means a law firm, forensic firm, negotiator, notification vendor, public relations firm or other provider on our current list of approved providers, available through the **Hotline**.
41. **“Payment Card Data”** means cardholder data and sensitive authentication data, as those terms are defined in the **PCI DSS**.
42. **“PCI Claim”** means a written demand by a payment card brand, acquiring bank or payment processor for **PCI Fines and Assessments** under a merchant services or similar agreement. **“PCI DSS”** means the Payment Card Industry Data Security Standard, as amended.
43. **“PCI Fines and Assessments”** means fines, penalties, fraud recoveries, operational reimbursements and case management fees that an **Insured** is required to pay under a merchant services or similar agreement because of actual or alleged non-compliance with the **PCI DSS**. It does not include interchange fees, chargebacks, the cost of becoming compliant, or fines for continued non-compliance after the **Security Failure** or **Privacy Event** has been fixed.
44. **“Period of Restoration”** means the period that begins when the **Interruption** begins and ends on the earlier of:
- (a) the date the affected computer system is restored, or with reasonable speed could have been restored, to the same condition and function it had before the **Interruption**, plus the time reasonably needed for your income to return to the level it would have reached had no **Interruption** occurred; or
 - (b) 180 days after the **Interruption** began.
45. **“Personal Information”** means information that identifies, or can reasonably be linked to, an individual, including names combined with Social Security numbers, taxpayer identification numbers, driver's license or passport numbers, financial account or payment card numbers, login credentials, health

information and biometric data, and any other information protected by a **Privacy Law**. It does not include information lawfully made available to the public by a government.

46. **"Policy Period"** means the period shown in Item 2 of the Declarations, or any shorter period if this policy is cancelled.
47. **"Privacy Event"** means:
- (a) the actual or reasonably suspected unauthorized access to, or acquisition, disclosure, loss or use of, **Personal Information** or **Confidential Information** in the care, custody or control of an **Insured**, or of a third party on your behalf, however it happens (including by the loss or theft of a device or paper records, or an employee's mistake); or
 - (b) an unintentional violation of a **Privacy Law** by an **Insured**.
48. **"Privacy Law"** means any law or regulation that governs the security, confidentiality or privacy of **Personal Information**, including data breach notification laws, the Health Insurance Portability and Accountability Act, the Gramm-Leach-Bliley Act and the Federal Trade Commission's Safeguards Rule, the California Consumer Privacy Act, and the EU and UK General Data Protection Regulations. It does not include biometric privacy laws, laws regulating unsolicited communications (such as the Telephone Consumer Protection Act and the CAN-SPAM Act), or any law to the extent a **Claim** alleges a **Tracking Wrongful Act**.
49. **"Privacy Wrongful Act"** means any actual or alleged act, error or omission by an **Insured** (or by a third party for whom an **Insured** is legally responsible) that results in a **Privacy Event**, including a failure to give timely notice of a **Privacy Event** as a **Privacy Law** requires, or a failure to follow your own published privacy policy.
50. **"Ransomware Event"** means a **Security Failure** in which malicious software encrypts, locks or otherwise makes **Data** or your **Computer System** unavailable, whether or not a demand for payment is made.
51. **"Regulatory Penalties"** means civil fines and penalties imposed on an **Insured** in a **Regulatory Proceeding**, and amounts an **Insured** must deposit into a consumer redress fund, where insurable under the law of the applicable jurisdiction that most favors coverage.
52. **"Regulatory Proceeding"** means a civil investigation, demand for information, administrative proceeding or civil lawsuit brought against an **Insured** by a government agency or regulator (including a state attorney general, the Federal Trade Commission, the U.S. Department of Health and Human Services, or a foreign data protection authority), started by a written notice received by an **Executive**.
53. **"Related"** means arising from the same, continuous or causally connected facts, circumstances, events or **Wrongful Acts**. All **Related Incidents** are one **Incident**, first **Discovered** when the earliest was first **Discovered**. All **Related Claims** are one **Claim**, first made when the earliest was first made.
54. **"Reputational Harm Loss"** means the net profit before taxes that you lose as a direct result of an **Adverse Publication**, calculated as Section V.I describes for **Income Loss**. It does not include **Breach Response Costs** or any **Business Interruption Loss**.
55. **"Restoration Costs"** means reasonable and necessary costs to:
- (a) restore, recreate or recollect **Data** and software to the condition they were in before the **Security Failure**, from backups or original sources;
 - (b) find and remove malicious code; and
 - (c) determine that **Data** cannot be restored or recreated, if that is the case.

It does not include the value of the **Data**, the cost of creating it originally, or the cost of improving any system.

56. **"Retention"** means the amount shown in Items 5 and 6 of the Declarations that you must pay for each **Incident** or **Claim** before we pay, as Section IV.D describes.
57. **"Retroactive Date"** means the date shown in Item 8 of the Declarations. If Item 8 shows "Full prior acts," no **Retroactive Date** applies.
58. **"Securities"** means negotiable and non-negotiable instruments or contracts that represent money or other property, not including **Money** or digital currency.
59. **"Security Failure"** means a failure or breach of the security of your **Computer System** (or, for Coverage E, of a **Dependent Business's** computer systems), including:
 - (a) unauthorized access to or use of the system, including with stolen credentials or credentials obtained by deception;
 - (b) a denial-of-service attack;
 - (c) the introduction or transmission of malicious code, including ransomware; and
 - (d) the loss or theft of **Hardware** containing **Data**.
60. **"Security Improvement Costs"** means reasonable costs of software, services and configuration (including multi-factor authentication, endpoint detection and response, managed detection and response for up to 12 months, and security awareness training) that a **Panel Provider** recommends in writing to prevent a similar **Incident**. It does not include **Hardware**, the salaries of your employees, or costs that you had already committed to before the **Incident**.
61. **"Security Wrongful Act"** means any actual or alleged act, error or omission by an **Insured** (or by a third party for whom an **Insured** is legally responsible) that results in a **Security Failure**, including a failure that allows malicious code to pass from your **Computer System** to a third party's systems, or that prevents authorized users from accessing your **Computer System**.
62. **"Social Engineering Fraud"** means the intentional deception of an **Insured** by someone impersonating a vendor, client, **Executive**, employee, financial institution or other trusted party, through email, telephone, text message, video call or other communication (including a **Deepfake**), which causes the **Insured** to transfer **Money** or **Securities** of the **Insured Organization**, or to change a payee's bank account or payment details, so that funds are paid to someone other than the intended recipient.
63. **"Subsidiary"** means an organization in which the **Named Insured** owns, directly or indirectly, more than 50% of the voting rights on the first day of the **Policy Period**, or that it acquires during the **Policy Period** as Section VI.G describes.
64. **"System Failure"** means an unintentional and unplanned outage of your **Computer System** caused by human error, a programming error, a failed software update or patch (including one issued by a vendor), or a malfunction of software or **Hardware**. It does not include a **Security Failure**.
65. **"Telecom Fraud"** means the unauthorized access to or use of your telephone or telecommunications systems by someone other than an **Insured**, resulting in charges to you.
66. **"Tracking Wrongful Act"** means the actual or alleged collection, interception, recording or sharing of information about visitors to your website or users of your online services through pixels, cookies, web beacons, session replay, chat tools or similar technology without the consent a law requires, in violation of a wiretapping, eavesdropping, video privacy or consumer privacy law.
67. **"Waiting Period"** means the number of hours shown for the applicable coverage in Item 6 of the Declarations, counted from when the **Interruption** begins.

68. “**Wrongful Act**” means a **Security Wrongful Act**, **Privacy Wrongful Act**, **Media Wrongful Act** or, if Coverage Q applies, a **Tracking Wrongful Act**.

SECTION III WHAT WE DO NOT COVER

IN SHORT Part A applies to every coverage. Part B adds a few exclusions that apply only to specific coverages. Many exclusions have exceptions (“This exclusion does not apply to...”) that restore coverage in specific situations.

A. EXCLUSIONS THAT APPLY TO ALL COVERAGES

We will not pay **Loss**, or provide services, based on, arising from or attributable to any of the following:

1. **Bodily injury and property damage.** **Bodily Injury**, or physical damage to or destruction of tangible property, including loss of use of that property. This exclusion does not apply to (a) mental anguish or emotional distress alleged in a **Claim** for a **Privacy Wrongful Act** or **Media Wrongful Act**; or (b) **Hardware** covered under Coverage N. **Data** is not tangible property.
2. **Prior knowledge and prior notice.** Any **Incident**, **Wrongful Act** or circumstance that (a) an **Executive** knew about before the **Continuity Date** and reasonably could have expected to lead to **Loss** or a **Claim**; or (b) was reported under any policy that was in force before this one.
3. **Prior or pending proceedings.** Any lawsuit, **Regulatory Proceeding** or other proceeding against an **Insured** that was pending before the **Continuity Date**, or any later **Claim** based on the same or **Related** facts.
4. **Intentional and dishonest acts.** Any dishonest, fraudulent, criminal or malicious act, or knowing violation of law, committed by an **Executive** or with an **Executive's** knowledge or consent. This exclusion applies only if a final, non-appealable judgment or ruling, or the **Insured's** own admission, establishes the conduct. We will defend the **Claim** until then. The conduct of one **Insured** is not imputed to any other natural person **Insured**. This exclusion does not apply to the acts of employees who are not **Executives**, if no **Executive** knew of or consented to them.
5. **War and state cyber operations.**
 - (a) **War**; or
 - (b) a **Cyber Operation** that has a major detrimental impact on the functioning of a **State** by significantly impairing that **State's** ability to provide **Essential Services**, or its security or defense.

Part (b) does not apply to your **Computer System** if it is not physically located in the impacted **State**. In deciding whether a **Cyber Operation** was carried out by, or at the direction of, a **State**, we will consider first whether the government of the **State** where your **Computer System** is located has attributed it to another **State**. Until any attribution is made, we may rely on an objectively reasonable inference from the available evidence. We have the burden of proving this exclusion applies. An act of terrorism, as defined in the Terrorism Risk Insurance Act, is not **War**. For this exclusion:

- (i) “**War**” means the use of physical force by a **State** against another **State**, or as part of a civil war, rebellion, revolution, insurrection or military or usurped power, whether or not war is declared;
- (ii) “**Cyber Operation**” means the use of a computer system by, or at the direction of, a **State** to disrupt, deny, degrade, manipulate or destroy information in a computer system of or in another **State**;
- (iii) “**State**” means a sovereign state; and

- (iv) “**Essential Services**” means services essential to the maintenance of vital functions of a **State**, including financial institutions and financial market infrastructure, health services and utility services.
6. **Infrastructure failure.** Any failure, interruption or outage of electricity, gas, water, internet backbone, telecommunications, satellite or other public infrastructure not under an **Insured's** operational control. This exclusion does not apply to a **Security Failure** of your own **Computer System**. A **Dependent Business** is not public infrastructure.
 7. **Natural perils.** Fire, smoke, explosion, lightning, wind, water, flood, earthquake, volcanic eruption, landslide, hail or any other natural peril. This exclusion does not apply to a **Privacy Event** involving lost or stolen devices or records, or to the loss or theft of **Hardware** described in Definition 59(d).
 8. **Pollution and nuclear.** The actual, alleged or threatened release of pollutants of any kind, or nuclear reaction, radiation or radioactive contamination.
 9. **Government seizure.** The seizure, confiscation, nationalization or destruction of your **Computer System** or **Data** by order of a government. This exclusion does not apply to a **Regulatory Proceeding** under Coverage J.
 10. **Contractual liability.** Liability an **Insured** assumed under a contract, warranty or guarantee. This exclusion does not apply to (a) liability the **Insured** would have had without the contract; (b) an obligation in a contract to protect the security or confidentiality of **Personal Information** or **Confidential Information**; or (c) **PCI Fines and Assessments** under Coverage K.
 11. **Professional services.** An act, error or omission in rendering, or failing to render, professional services to others (for example accounting, tax, legal, financial, consulting or technology advice or work). This exclusion does not apply to **Loss** under the first-party coverages, or to the extent a **Claim** alleges a **Security Wrongful Act** or **Privacy Wrongful Act**.
 12. **Securities, antitrust and unfair trade.** Any actual or alleged violation of securities laws; antitrust, price-fixing or restraint of trade laws; or laws against unfair or deceptive trade practices. The last part does not apply to a **Claim** or **Regulatory Proceeding** arising from a **Security Failure** or **Privacy Event**.
 13. **Employment practices and benefit plans.** Employment-related practices, including wrongful termination, discrimination and harassment, or the administration of any employee benefit plan. This exclusion does not apply to a **Claim** arising from a **Privacy Event** involving the **Personal Information** of employees or plan participants.
 14. **Intellectual property.** Infringement or misappropriation of any patent or trade secret, or infringement of any other intellectual property right. This exclusion does not apply to (a) a **Media Wrongful Act** other than patent infringement or trade secret misappropriation; or (b) the disclosure of a third party's trade secret that is **Confidential Information** because of a **Security Failure** or **Privacy Event**.
 15. **Wrongful collection and tracking.**
 - (a) The collection, capture, storage or use of biometric information (such as fingerprints, voiceprints, or scans of the face, hand, retina or iris) in violation of any law, including the Illinois Biometric Information Privacy Act; or
 - (b) a **Tracking Wrongful Act**, unless Coverage Q applies.

This exclusion does not apply to a **Privacy Event** caused by a **Security Failure**, such as the theft of stored biometric data by a hacker.
 16. **Unsolicited communications.** Any actual or alleged violation of the Telephone Consumer Protection Act, the CAN-SPAM Act, or any other law regulating telemarketing, unsolicited calls, texts, faxes or emails. This

exclusion does not apply if the communications were sent by a third party through unauthorized access to your **Computer System**.

17. **Insured versus Insured.** A **Claim** brought by or on behalf of one **Insured** against another. This exclusion does not apply to a **Claim** by an employee arising from a **Privacy Event** involving that employee's **Personal Information**, or to a **Claim** by an additional insured described in Definition 31(d).
18. **Money, securities and trading.** The loss, theft, or reduction in value of **Money, Securities**, digital currency or other financial assets of an **Insured**, or any trading loss. This exclusion does not apply to an **Extortion Payment** under Coverage C or **Direct Financial Loss** under Coverage H.
19. **Betterment and ordinary business costs.** The cost of upgrading, improving or replacing any system beyond its condition before the **Incident**, except as covered under Coverage G or N; or your ordinary operating costs, salaries and overhead, except as part of **Income Loss** or **Extra Expense**.
20. **Value of data and intellectual property.** The monetary value of **Data**, trade secrets or other intellectual property of an **Insured**, including the cost of the research or development used to create it.

B. EXCLUSIONS THAT APPLY TO SPECIFIC COVERAGES

1. **Business interruption (Coverages D, E and M).** We will not pay for:
 - (a) loss caused by unfavorable business conditions, loss of market, or any other loss beyond the **Period of Restoration**;
 - (b) an **Interruption** caused by planned or scheduled downtime or maintenance, or by ordinary wear and tear;
 - (c) contractual penalties, service credits or liquidated damages for failing to perform a contract;
 - (d) legal costs or **Claim**-related amounts, which are covered, if at all, only under the liability coverages; or
 - (e) under Coverages D and M, an **Interruption** of a **Dependent Business's** computer systems, which is covered, if at all, only under Coverage E.
2. **Fraud (Coverage H).** We will not pay for:
 - (a) any loss caused by a dishonest or fraudulent act of an **Insured**, whether acting alone or in collusion with others (employee theft is a matter for a crime or fidelity policy);
 - (b) any payment for goods, services or investments that were genuinely provided or offered, even if they turned out to be worth less than expected or were misrepresented by the seller;
 - (c) any loss arising from credit you extended, or a customer's failure to pay, except as covered for **Invoice Manipulation**; or
 - (d) any amount you recover from your financial institution, the recipient or any other source.
3. **Media (Coverage L).** We will not pay for a **Claim** arising from (a) false, misleading or comparative advertising about the price or quality of your own goods or services; (b) the failure of goods or services to conform to their advertised quality or performance; or (c) a dispute with an independent contractor or former employee over ownership of **Media Content** they created for you.

SECTION IV LIMITS, RETENTION AND COINSURANCE

IN SHORT We pay up to \$1,000,000 in total. You pay one retention per incident. The first 72 hours of incident response are free. Keeping the security controls you told us about keeps your best terms.

A. Policy Aggregate Limit

The Policy Aggregate Limit in Item 4 of the Declarations is the most we will pay for all **Loss** under all coverages combined, including **Claim Expenses**, for the **Policy Period** and any **Extended Reporting Period**. When it is used up, we have no further obligation to pay **Loss** or to defend any **Claim**.

B. Coverage limits

The limit shown for each coverage in Item 6 is the most we will pay for all **Loss** under that coverage. Each coverage limit is part of, and not in addition to, the Policy Aggregate Limit, even where the two amounts are the same. Payments under a coverage reduce both its limit and the Policy Aggregate Limit.

C. Incident Response Services

Incident Response Services under Coverage A do not reduce any limit, and no **Retention** applies to them.

D. Retention

1. You must pay the **Retention** for each **Incident** or **Claim** before we pay **Loss**. **Claim Expenses** count toward the **Retention**. We may pay **Loss** within the **Retention** and ask you to repay us.
2. **One retention per incident**. If a single **Incident**, including any **Claims** arising from it, triggers more than one coverage, you pay only the largest single **Retention** that applies.
3. No **Retention** applies to Coverage A or Coverage G. For Coverages D, E and M, the **Waiting Period** applies instead of a dollar **Retention**.
4. For Coverage H, if Coverage H, paragraph 4, is met, the **Retention** is half of the amount that would otherwise apply to that **Incident** (for example, \$2,500 instead of \$5,000). If the same **Incident** also triggers another coverage, paragraph 2 applies.

E. Waiting Period

For Coverages D, E and M, we pay only if the **Interruption** lasts longer than the **Waiting Period**, and we do not pay **Business Interruption Loss** incurred during the **Waiting Period**. If an **Interruption** stops and then restarts from the same cause within 72 hours, we treat it as one continuous **Interruption**.

F. Related Incidents and Claims

Related Incidents and **Related Claims** are treated as a single **Incident** or **Claim**. One **Retention** applies, and only the limits of the policy in force when the first of them was **Discovered** or made apply, even if some occur after this policy ends.

G. Security credit adjustment

1. Item 7 of the Declarations lists security credits you earned, based on the controls described in your **Application**. If one of those controls was not in place when an **Incident** began, we will adjust the terms for that **Incident** only, as if that credit had not been earned:
 - (a) MFA and endpoint detection and response: the **Retention** for that **Incident** becomes the standard retention in Item 5;
 - (b) backups: the ransomware coinsurance in Section IV.H applies; and
 - (c) callback verification: the Coverage H limit for that **Incident** becomes \$100,000.
2. We will not make this adjustment if (a) the control was not in place for less than 30 days because of a change you were actively fixing; or (b) the missing control did not contribute to the **Incident** or increase the **Loss**.

3. This adjustment replaces any right we might otherwise have to deny coverage, or to rescind or cancel this policy, because a control was not in place. It does not limit our rights under Section VI.A if the **Application** contained a misrepresentation made with intent to deceive.

H. Ransomware coinsurance

If Item 7 shows that the backup credit was not earned, or Section IV.G applies to it, you will bear 20% of all **Loss** arising from a **Ransomware Event** after the **Retention**, and we will pay 80%. Our share is subject to the applicable limits. Coinsurance does not apply to **Incident Response Services**.

I. Allocation

If a **Claim** or **Incident** involves both covered and uncovered matters or parties, we will pay 100% of **Claim Expenses** until the covered matters are resolved. For all other **Loss**, you and we will each use best efforts to agree on a fair allocation based on the relative legal and financial exposures.

SECTION V WHEN SOMETHING HAPPENS

IN SHORT Call us as soon as you can. Use our panel for the fastest response. Make legal notices on time. Don't pay ransoms, settle or admit fault without us.

A. Reporting Incidents and Claims

1. You must report every **Incident** and **Claim** to us through the **Hotline** as soon as practicable after an **Executive** first **Discovers** the **Incident** or receives the **Claim**.
2. **Claims** must be reported during the **Policy Period**, or no later than 60 days after it ends (or during any **Extended Reporting Period**).
3. **Incidents** under the first-party coverages must be reported no later than 60 days after the **Policy Period** ends. We will not deny coverage for an **Incident** because it was reported late within that window unless the delay materially harmed our ability to investigate or reduce the **Loss**, and then only to the extent of that harm.
4. Your report should include what happened, when it was **Discovered**, the systems and information involved, and copies of any **Claim**, demand or notice received.

B. Notice of circumstances

If, during the **Policy Period**, you become aware of circumstances that could reasonably lead to a **Claim**, and you give us written notice describing them (including the **Wrongful Act**, the people involved and why a **Claim** is expected), any later **Claim** arising from those circumstances will be treated as first made on the date of your notice.

C. Panel Providers and your choice of providers

1. You may use any **Panel Provider** without asking us for further consent. Their rates are pre-agreed with us.
2. You may ask to use a provider that is not on our panel. We will not unreasonably withhold consent. We will pay that provider's reasonable fees up to the amount we would have paid a **Panel Provider** for comparable services.
3. If you incur reasonable costs to contain an **Incident** in an emergency before you can reach us, we will treat them as if we had consented, provided you report the **Incident** within 48 hours after incurring them.

D. Legal notification deadlines

You never need our consent to make a notification that a law or regulation requires, or to meet a legal deadline. We will not deny or reduce coverage because you made a legally required notification without our consent.

E. Your other duties after an Incident or Claim

Every **Insured** must:

- (a) take reasonable steps to contain the **Incident** and reduce **Loss**;
- (b) preserve evidence, including logs, affected devices, emails and ransom notes, and not wipe or rebuild affected systems until our forensic provider agrees;
- (c) cooperate with us and our **Panel Providers**, give us access to relevant systems, records and people, and help us enforce any rights against others;
- (d) not admit liability, make settlement offers, agree to pay any amount, or incur **Claim Expenses** without our prior consent, except as allowed in Section V.D; and
- (e) tell us promptly about any recovery or payment received from another source.

F. Extortion demands

Before any **Extortion Payment** is made:

- (a) you must obtain our written consent, and must not pay, promise to pay or negotiate a payment without it;
- (b) you must, where we reasonably ask, report the threat to the Federal Bureau of Investigation or another appropriate law enforcement agency;
- (c) you must allow us, or a **Panel Provider**, to check that the payment does not involve a person, organization or country subject to economic sanctions (see Section VI.K); and
- (d) you must take reasonable steps to confirm that the threat is credible and that restoring from backups is not a reasonable alternative.

We may pay the **Extortion Payment** directly or reimburse you. Paying an **Extortion Payment** is always your decision. We will never require you to make one.

G. Fraudulent payments

If you **Discover Funds Transfer Fraud, Social Engineering Fraud or Invoice Manipulation**, you must, as soon as possible, (a) ask your financial institution to stop, recall or reverse the transfer; (b) file a complaint with the FBI Internet Crime Complaint Center (ic3.gov) or other law enforcement; and (c) report it to us through the **Hotline**. Within 90 days after **Discovery**, you must send us a signed proof of loss with supporting records.

H. Defense and settlement

1. We have the right and duty to defend any **Claim** covered under Coverages I, J, K, L and Q, even if its allegations are groundless or false. We will appoint defense counsel, normally a **Panel Provider**. We will consider in good faith any counsel you propose.
2. We will not settle a **Claim** without your consent. If you refuse a settlement that we recommend and that the claimant is willing to accept, the most we will pay for that **Claim** is the amount of the recommended settlement, plus **Claim Expenses** incurred up to the date you refused, plus 70% of any **Loss** after that date. You will bear the remaining 30%.
3. You may settle any **Claim** for a total amount within the **Retention**, with our consent, which we will not unreasonably withhold.

I. Business interruption: proving and calculating your loss

1. You must send us a proof of loss within 180 days after the **Period of Restoration** ends. We will extend this deadline if you ask before it passes.
2. We will calculate **Income Loss** using your net profit and operating expenses in the 12 months before the **Interruption**, adjusted for seasonal patterns, trends, and the business you would reasonably have done during the **Period of Restoration**. We will take into account any business you make up after the **Interruption** ends, and any expenses you save because of it.
3. You must use reasonable efforts to resume operations, including by using other systems, locations or providers, and to reduce the **Loss**.

J. Appraisal

If you and we disagree only on the amount of **Business Interruption Loss**, **Restoration Costs** or **Hardware** replacement costs, either may demand an appraisal in writing. Each will choose an independent appraiser within 20 days. The appraisers will choose an umpire. A decision agreed by any two of the three is binding on the amount only. Each party pays its own appraiser and half of the umpire's fees.

K. Payment

We will pay covered **Loss** within 30 days after we receive the documents we reasonably need to verify it, or after an agreement, judgment or appraisal award fixes the amount. Where it is clear that part of a first-party **Loss** is covered, we will pay that part without waiting for the rest to be settled.

SECTION VI GENERAL CONDITIONS**A. The Application**

We issued this policy relying on the **Application**, which is part of this policy. The knowledge of one natural person **Insured** is not imputed to any other natural person **Insured**. Only the knowledge of the person who signed the **Application** and of **Executives** is imputed to the **Insured Organization**. We may rescind this policy only if the **Application** contained a misrepresentation that was made with intent to deceive and that materially affected our decision to issue the policy or its terms. Inaccurate statements about security controls that were not made with intent to deceive are dealt with only under Section IV.G.

B. The Named Insured acts for all Insureds

The **Named Insured** acts on behalf of every **Insured** to give and receive notices, pay premiums, receive return premiums, agree to changes, and buy an **Extended Reporting Period**.

C. Cancellation

1. You may cancel this policy at any time by notifying us. We will refund the unearned premium on a pro rata basis.
2. We may cancel this policy only (a) for non-payment of premium, by giving you at least 10 days' written notice; or (b) for fraud or a material misrepresentation described in Section VI.A, by giving you at least 30 days' written notice. We will refund any unearned premium pro rata.

D. Extended Reporting Period

1. **Automatic.** If this policy is cancelled or not renewed for any reason other than non-payment of premium or fraud, you automatically have 60 days after the **Policy Period** ends to report **Claims** first made during those 60 days, at no additional cost.

2. **Optional.** In the same circumstances, you may instead buy an optional **Extended Reporting Period** of 12 months, for 75% of the annual premium, or 24 months, for 125%, by asking in writing and paying within 60 days after the **Policy Period** ends. It starts when the **Policy Period** ends and replaces the automatic period. The premium is fully earned when paid.
3. Any **Extended Reporting Period** applies only to **Claims** for **Wrongful Acts** committed before the **Policy Period** ends. It does not increase or reinstate any limit, and it does not extend the first-party coverages.

E. Nonrenewal

If we decide not to renew this policy, or to renew it with a premium increase or reduced coverage, we will give you written notice at least 60 days before the **Policy Period** ends, or longer if state law requires.

F. Change in control

If, during the **Policy Period**, the **Named Insured** merges into or is acquired by another organization, or any person or group acquires more than 50% of its voting rights, this policy will continue until the end of the **Policy Period**, but only for **Incidents Discovered**, and **Wrongful Acts** committed, before the change. You must notify us within 30 days after the change. You may ask us to continue full coverage, and we may agree subject to additional terms and premium.

G. New Subsidiaries and acquisitions

If the **Named Insured** creates or acquires an organization during the **Policy Period** whose annual revenue is less than 20% of the **Named Insured's**, that organization is automatically a **Subsidiary**. If its revenue is 20% or more, it is a **Subsidiary** for 90 days after the acquisition, and after that only if we agree in writing. Coverage for a new **Subsidiary** applies only to **Incidents** and **Wrongful Acts** that happen after its creation or acquisition.

H. Territory

This policy applies to **Incidents** occurring, and **Claims** brought, anywhere in the world, where legally permissible and subject to Section VI.K.

I. Other insurance

This policy is excess over any other valid insurance that applies to the same **Loss**, unless that insurance is written specifically as excess of this policy. **Incident Response Services** are always provided on a primary basis.

J. Subrogation and recoveries

If we pay **Loss**, we take over your rights of recovery against others to the extent of our payment, and you must help us enforce them. We waive this right against any person or organization you agreed in writing, before the **Incident**, not to pursue. Any recovery will be applied, after deducting the costs of obtaining it, first to repay you for **Loss** above the limits, then to repay us, and then to repay you for the **Retention** and any coinsurance.

K. Sanctions

We will not provide coverage, pay any **Loss** or provide any benefit to the extent that doing so would expose us to any sanction, prohibition or restriction under the laws or regulations of the United States (including those administered by the Office of Foreign Assets Control), the United Nations, the European Union or the United Kingdom.

L. Action against us

No one may bring legal action against us under this policy unless they have complied with its terms. For the liability coverages, no one may sue us to recover **Damages** until the **Insured's** obligation to pay has been fixed

by a final judgment or by a written settlement agreement that we consented to. No one has a right under this policy to join us as a party to a **Claim** against an **Insured**.

M. Assignment

You may not assign your rights under this policy without our written consent.

N. Bankruptcy

The bankruptcy or insolvency of any **Insured** does not relieve us of our obligations under this policy.

O. Resolving disagreements

If you and we disagree about this policy, either may ask for non-binding mediation with a mutually agreed mediator, whose fees we will share equally. If the disagreement is not resolved within 60 days after mediation is requested, either may bring an action in a court of competent jurisdiction. This does not limit the appraisal process in Section V.J.

P. Choice of law

This policy is governed by the law of the state shown in Item 11 of the Declarations, except where another state's law must apply. The most-favorable-law provisions in Definitions 14 and 51 apply regardless of this condition.

Q. Conformity to law

Any term of this policy that conflicts with the law of the state in Item 11 is amended to conform to the minimum requirements of that law.

R. Automatic improvements

If, during the **Policy Period**, we file a revision of this policy form that broadens coverage without additional premium, the broader coverage will apply to this policy from the date the revision takes effect in your state.

S. Currency

All amounts are in U.S. dollars. **Loss** incurred in another currency is converted at the exchange rate published by the Wall Street Journal on the date the **Loss** is paid or the judgment or settlement is entered.

T. Risk management services

We may offer optional services, such as external security scans, security alerts and training. Using them is voluntary. Your decision not to use them will not affect your coverage, and our scans are not part of your **Application**.

U. Headings and summaries

Headings, the "In short" summaries and the plain-English descriptions in the Declarations are for convenience only. They do not form part of the terms of this policy and do not affect its meaning.

V. Entire agreement and changes

This policy (the Declarations, this form, the **Application**, and the endorsements and disclosures listed in Item 12 of the Declarations) is the entire agreement between you and us. It can be changed only by an endorsement that we issue.

In witness whereof, Harborline Insurance Company has caused this policy to be signed by its President and Secretary. Where required by law, this policy is not valid unless countersigned by an authorized representative of the company.

Eleanor Voss

Eleanor M. Voss, President

Marcus Hale

Marcus T. Hale, Secretary

— END OF POLICY FORM HIC-CY-100 (10/26) —

Policyholder Disclosure: Notice of Terrorism Insurance Coverage

Coverage for acts of terrorism is included in your policy. You are hereby notified that under the Terrorism Risk Insurance Act, as amended, you have a right to purchase insurance coverage for losses resulting from acts of terrorism. As defined in Section 102(1) of the Act, the term “act of terrorism” means any act or acts that are certified by the Secretary of the Treasury, in consultation with the Secretary of Homeland Security and the Attorney General of the United States, to be an act of terrorism; to be a violent act or an act that is dangerous to human life, property, or infrastructure; to have resulted in damage within the United States, or outside the United States in the case of certain air carriers or vessels or the premises of a United States mission; and to have been committed by an individual or individuals as part of an effort to coerce the civilian population of the United States or to influence the policy or affect the conduct of the United States Government by coercion.

YOU SHOULD KNOW THAT WHERE COVERAGE IS PROVIDED BY THIS POLICY FOR LOSSES RESULTING FROM CERTIFIED ACTS OF TERRORISM, SUCH LOSSES MAY BE PARTIALLY REIMBURSED BY THE UNITED STATES GOVERNMENT UNDER A FORMULA ESTABLISHED BY FEDERAL LAW. HOWEVER, YOUR POLICY MAY CONTAIN OTHER EXCLUSIONS WHICH MIGHT AFFECT YOUR COVERAGE, SUCH AS AN EXCLUSION FOR NUCLEAR EVENTS. UNDER THE FORMULA, THE UNITED STATES GOVERNMENT GENERALLY REIMBURSES 80% OF COVERED TERRORISM LOSSES EXCEEDING THE STATUTORILY ESTABLISHED DEDUCTIBLE PAID BY THE INSURANCE COMPANY PROVIDING THE COVERAGE. THE PREMIUM CHARGED FOR THIS COVERAGE IS PROVIDED BELOW AND DOES NOT INCLUDE ANY CHARGES FOR THE PORTION OF LOSS THAT MAY BE COVERED BY THE FEDERAL GOVERNMENT UNDER THE ACT.

YOU SHOULD ALSO KNOW THAT THE TERRORISM RISK INSURANCE ACT, AS AMENDED, CONTAINS A \$100 BILLION CAP THAT LIMITS U.S. GOVERNMENT REIMBURSEMENT AS WELL AS INSURERS' LIABILITY FOR LOSSES RESULTING FROM CERTIFIED ACTS OF TERRORISM WHEN THE AMOUNT OF SUCH LOSSES IN ANY ONE CALENDAR YEAR EXCEEDS \$100 BILLION. IF THE AGGREGATE INSURED LOSSES FOR ALL INSURERS EXCEED \$100 BILLION, YOUR COVERAGE MAY BE REDUCED.

POLICY NUMBER	TERRORISM PREMIUM
HIC-CY-2026-004817	\$0 (included; no separate charge)

This disclosure is part of your policy (see Item 12 of the Declarations). As Section III.A.5 of the policy states, an act of terrorism is not treated as war.



HARBORLINE
INSURANCE
COMPANY

Cyber Protection Policy Application

New business and renewal · Small and mid-sized businesses
Form HIC-CY-APP (10/26)

SPECIMEN — completed sample for illustration only. Harborline Insurance Company and the applicant below are fictional.

BEFORE YOU START

- This is an application for a policy whose liability coverages are **claims-made and reported**. Completing it does not bind coverage.
- Answer every question. Your answers to questions marked **CREDIT** set the security credits in Item 7 of your Declarations: a lower retention, no ransomware coinsurance and a full fraud limit.
- If an IT provider manages your systems, ask them to help with Section 5. It takes about 20 minutes.
- Tags such as **PR.AA** show which NIST Cybersecurity Framework 2.0 category each security question relates to.

1 APPLICANT INFORMATION

Legal name of applicant	Cedar Ridge Accounting Group, LLC		
Principal address	1450 Market Street, Suite 600, Denver, CO 80202		
Other locations	1919 14th Street, Suite 300, Boulder, CO 80302 (satellite office, 9 staff)		
Website and email domains	cedarridgecpa.com	Main phone	(303) 555-0100
Entity type	Limited liability company	Year established	2009
FEIN	XX-XXX4417	NAICS code	541211 (Offices of CPAs)
Primary contact	Dana Whitfield, CPA, Managing Partner	Email / phone	dana.whitfield@cedarridgecpa.com (303) 555-0187
IT / security contact	Marcus Lee, Operations & IT Manager	IT provider (MSP)	Summit Peak Technology Partners Priya Raman, vCIO · (303) 555-0164
Subsidiaries to be insured	None		

2 BUSINESS OPERATIONS AND REVENUE

Description of operations	CPA firm providing individual and business tax preparation and planning (48% of revenue), audit and assurance (22%), outsourced bookkeeping and accounting (18%) and advisory / fractional CFO services (12%) to about 2,100 clients (1,450 individuals and families, 650 businesses), mainly in Colorado.		
Employees	52 (46 full-time, 6 seasonal)		Owners / partners 5
Annual revenue	LAST COMPLETED FISCAL YEAR (2025)	CURRENT YEAR, PROJECTED (2026)	NEXT YEAR, PROJECTED (2027)
	\$11,400,000	\$12,600,000	\$13,300,000
Revenue by location	Colorado 94% · Other U.S. states 6% · Outside the U.S. 0%		
Seasonality	About 45% of annual revenue is earned February 1 – April 30, with a second peak before October 15 extension deadlines.		

3 COVERAGE REQUESTED

Requested effective date	October 15, 2026	New or renewal	☒ New ☐ Renewal
Policy aggregate limit	☒ \$1,000,000 ☐ \$2,000,000 ☐ \$3,000,000 ☐ \$5,000,000		

Optional coverages	OPTIONAL COVERAGE		REQUESTED?
	M	System Failure Business Interruption	☐ Yes ☒ No
	N	Computer Replacement (Bricking), \$100,000	☒ Yes ☐ No
	O	Reputational Harm	☐ Yes ☒ No
	P	Cryptojacking and Telecom Fraud, \$50,000	☒ Yes ☐ No
	Q	Website Tracking Liability	☐ Yes ☒ No
	R	Increased Fraud Limit (\$500,000)	☐ Yes ☒ No
Prior acts coverage	Full prior acts requested. We have not had a standalone cyber policy before (see Section 8).		

4 DATA YOU HOLD AND PRIVACY PRACTICES

Individuals whose personal information you hold	About 14,200 (current and former clients and their dependents, and current and former employees)		
TYPE OF RECORD	HELD?	APPROX. NUMBER	WHERE IT IS STORED
Social Security or taxpayer ID numbers	☒ Yes ☐ No	13,600	Cloud tax and practice-management platform; Microsoft 365
Bank or financial account numbers	☒ Yes ☐ No	6,400	Tax platform (refund and payment details)
Driver's license or passport copies	☒ Yes ☐ No	3,000	Client portal (identity verification)
Health information	☒ Yes ☐ No	2,000	Tax records only (medical expenses, HSA)
Payment card data stored or processed on your systems	☐ Yes ☒ No	0 stored	Clients pay through a third-party hosted payment page (about 1,300 card payments a year)
Biometric information	☐ Yes ☒ No	—	—
4.1	Do you have a written information security plan (WISP), as the FTC Safeguards Rule requires for tax preparers? GV.PO Updated March 2026; reviewed annually with our MSP.		☒ Yes ☐ No
4.2	Is full-disk encryption enabled on all laptops and desktops? PR.DS		☒ Yes ☐ No
4.3	Do you exchange sensitive documents with clients only through a secure portal or encrypted email? PR.DS		☒ Yes ☐ No
4.4	Do you have a data retention and destruction policy? PR.DS 7 years after engagement ends, then secure deletion.		☒ Yes ☐ No
4.5	Does your website use advertising pixels, session replay, chat tools or other tracking technology (other than basic analytics)? Google Analytics 4 only, with a cookie consent banner.		☐ Yes ☒ No
4.6	Do you sell, rent or share personal information with third parties for their own marketing?		☐ Yes ☒ No
4.7	If you accept payment cards, have you completed a PCI DSS self-assessment in the last 12 months? SAQ A, completed February 2026.		☒ Yes ☐ No

5 SECURITY CONTROLS

Answer "Yes" only if the control is in place today for all users and systems described. If a control is partly in place, answer "No" and explain.

5.1	Is multi-factor authentication (MFA) required for: CREDIT PR.AA	
	(a) email, for all users?	☒ Yes ☐ No
	(b) all remote access to your network?	☒ Yes ☐ No
	(c) all administrator and privileged accounts?	☒ Yes ☐ No
	(d) cloud applications holding client data, online banking and the backup console? Microsoft Entra conditional access; authenticator app with number matching for staff, hardware security keys for the 3 admin accounts. No remote desktop (RDP) open to the internet.	☒ Yes ☐ No
5.2	Is endpoint detection and response (EDR) installed on all laptops, desktops and servers? CREDIT DE.CM Microsoft Defender for Business on 58 of 58 devices.	☒ Yes ☐ No
5.3	Are security alerts monitored 24/7 by a managed detection and response (MDR) service or security operations center? CREDIT DE.CM Our MSP reviews alerts 7 a.m.–7 p.m. on weekdays (extended hours in tax season). We are pricing a 24/7 MDR service for 2027.	☐ Yes ☒ No
5.4	Do you use advanced email filtering, flag external emails, and enforce DMARC at "quarantine" or "reject"? PR.PS	☒ Yes ☐ No
5.5	Are critical security patches applied within 14 days, and is all software in use still supported by its vendor? PR.PS Critical patches within 7 days on endpoints, 14 days on network devices. No end-of-life systems.	☒ Yes ☐ No
5.6	Do staff work without local administrator rights, with separate accounts for administrative tasks? PR.AA	☒ Yes ☐ No
5.7	Backups: CREDIT RC.RP	
	(a) Are critical data and systems backed up at least weekly?	☒ Yes ☐ No
	(b) Is at least one copy offline or immutable (it cannot be changed or deleted)?	☒ Yes ☐ No
	(c) Are backups protected by separate credentials and MFA?	☒ Yes ☐ No
	(d) Have you successfully tested restoring from backup in the last 12 months? Daily immutable cloud backups of Microsoft 365 and tax platform exports, plus a weekly offline copy. Full restore test on June 12, 2026: SharePoint library and practice-management export restored in 5.5 hours.	☒ Yes ☐ No
5.8	Do all staff complete security awareness training at least annually, with phishing simulations? PR.AT Annual training, monthly simulations. Click rate last quarter: 3.8%.	☒ Yes ☐ No
5.9	Do you have a written incident response plan that has been tested in the last 12 months? RS.MA Plan updated and tabletop exercise held with our MSP in January 2026.	☒ Yes ☐ No
5.10	Do you keep an inventory of hardware, software and cloud services? ID.AM	☒ Yes ☐ No
5.11	Do you review the security of key technology vendors (for example SOC 2 reports) at least annually? GV.SC	☒ Yes ☐ No

6 PAYMENTS AND FRAUD CONTROLS

6.1	Do you send wire or ACH payments? About 45 outbound payments a month. Largest single payment in the last 12 months: \$62,400 (office lease).	☒ Yes ☐ No
-----	--	---

6.2	Before paying a new payee, or changing any payee's bank details, do you always confirm the request by calling a phone number you already had on file (not one in the request)? CREDIT PR.AA Written procedure since March 2024. Staff record each verification in the payment file.	☒ Yes ☐ No
6.3	Do payments over \$10,000 need approval from two people?	☒ Yes ☐ No
6.4	Do you use positive pay or ACH debit blocks with your bank?	☒ Yes ☐ No
6.5	Do you hold, move or have signing authority over client funds?	☐ Yes ☒ No
6.6	Do your invoices tell clients that your bank details will never change by email?	☒ Yes ☐ No

7 TECHNOLOGY PROVIDERS AND BUSINESS CONTINUITY

PROVIDER OR SERVICE YOU DEPEND ON	TYPE	WRITTEN CONTRACT?	HOW LONG COULD YOU OPERATE WITHOUT IT?
Microsoft 365 (email, files)	SaaS	☒ Yes ☐ No	Less than 1 day
Cloud tax preparation and practice-management platform	SaaS	☒ Yes ☐ No	4 hours in tax season; 1 day otherwise
Secure client portal	SaaS	☒ Yes ☐ No	2–3 days
Summit Peak Technology Partners (network, devices, help desk)	Managed IT	☒ Yes ☐ No	1 week
Cloud backup provider	SaaS	☒ Yes ☐ No	1 week
7.1	Could your staff keep working (for example remotely, on company laptops) if your office network were unavailable? RC.RP	☒ Yes ☐ No	
7.2	Estimated revenue lost for each business day your systems are fully down: About \$90,000 in tax season (February–April); about \$36,000 at other times.		

8 PRIOR INSURANCE, INCIDENTS AND CLAIMS

8.1	Do you currently have cyber insurance? No standalone cyber policy. Our businessowners policy includes a \$50,000 data compromise endorsement, expiring October 15, 2026. We will remove it when this policy starts.	☒ Yes ☐ No
8.2	In the last 3 years, has any insurer declined, cancelled or refused to renew cyber insurance for you?	☐ Yes ☒ No
8.3	In the last 5 years, have you had any data breach, ransomware attack, extortion demand, fraudulent payment, or attempt at any of these? If yes, describe it in 8.4.	☒ Yes ☐ No
8.4	Details: March 2024, attempted business email compromise with no loss. A fraudster spoofed a client's email domain and asked our bookkeeper to change that client's vendor bank details. The bookkeeper called the client on the number on file, the request was confirmed as fraud, and no payment was made. No data was accessed. Afterward we moved DMARC to "quarantine," formalized our callback procedure (6.2) and made phishing simulations monthly.	
8.5	In the last 5 years, has anyone made a claim, lawsuit or regulatory inquiry against you about privacy, data security or online content?	☐ Yes ☒ No
8.6	After reasonable inquiry, is any partner, officer or IT manager aware of any fact or circumstance that could lead to a claim or loss under the proposed policy?	☐ Yes ☒ No

9 DOCUMENTS ATTACHED

☒ MFA conditional access policy export (5.1)	☒ Backup restore test report, June 12, 2026 (5.7)
☒ EDR device coverage report, 58 of 58 devices (5.2)	☒ Callback verification procedure, March 2024 (6.2)
☒ PCI DSS SAQ A, February 2026 (4.7)	☐ Written information security plan (available on request)

10 DECLARATION AND SIGNATURE

By signing, I confirm on behalf of the applicant that:

- I am authorized to sign for the applicant, and I made reasonable inquiry of its partners, officers and IT provider before answering.
- The statements in this application and its attachments are true and complete to the best of my knowledge.
- I will tell Harborline promptly if any answer changes materially before the policy starts. Harborline may change or withdraw its quote if that happens.
- This application will form part of the policy if one is issued, and Harborline will rely on it. Harborline may verify my answers, including by scanning our internet-facing systems.

Fraud warning (all states). Any person who knowingly and with intent to defraud any insurance company or other person files an application for insurance or statement of claim containing any materially false information, or conceals for the purpose of misleading information concerning any fact material thereto, commits a fraudulent insurance act, which is a crime and may subject that person to criminal and civil penalties.

Colorado. It is unlawful to knowingly provide false, incomplete, or misleading facts or information to an insurance company for the purpose of defrauding or attempting to defraud the company. Penalties may include imprisonment, fines, denial of insurance, and civil damages. Any insurance company or agent of an insurance company who knowingly provides false, incomplete, or misleading facts or information to a policyholder or claimant for the purpose of defrauding or attempting to defraud the policyholder or claimant with regard to a settlement or award payable from insurance proceeds shall be reported to the Colorado Division of Insurance within the Department of Regulatory Agencies.

	<u>Dana Whitfield, CPA</u>	<u>Managing Partner</u>	<u>September 24, 2026</u>
Signature of authorized officer	Printed name	Title	Date

I HOW YOUR ANSWERS AFFECT YOUR POLICY

For information. This is how Harborline turns the answers above into the terms shown in your Declarations.

YOUR ANSWER	EFFECT ON YOUR POLICY	DECLARATIONS
5.1 and 5.2 all "Yes"	Retention cut from \$10,000 to \$5,000, plus a 10% premium credit	Items 3, 5 and 7
5.7 all "Yes"	No ransomware coinsurance (otherwise you pay 20% of ransomware losses)	Item 7; policy Section IV.H
6.2 "Yes"	Coverage H at the full \$250,000 (otherwise \$100,000)	Items 6 and 7
5.3 "Yes"	Business interruption waiting period cut from 8 to 4 hours	Items 6 and 7
4.5 "Yes"	We recommend optional Coverage Q (website tracking liability)	Item 6, Part 2
Section 2 revenue	Sets your standard retention band and base premium	Items 3 and 5

If a credited control stops being in place, your policy does not become void. For an incident that happens while it is missing, the terms revert to what they would have been without the credit (policy Section IV.G).

FOR HARBORLINE USE ONLY · UNDERWRITING SUMMARY

Reviewed	J. Okafor, Underwriter · September 30, 2026
Revenue band	\$5M–\$25M (2026 projected \$12.6M) · standard retention \$10,000
Security credits verified	✓ MFA + EDR (conditional access export; 58/58 devices) ✓ Backups (restore test 06/12/2026) ✓ Callback procedure ✗ 24/7 MDR
Result	Retention \$5,000 · no ransomware coinsurance · Coverage H at \$250,000 · waiting period 8 hours
Premium	Base \$6,120 (includes optional N and P) · security credit –10% (–\$612) · total \$5,508
Decision	Approved. Issue policy HIC-CY-2026-004817, effective October 15, 2026. Note for renewal: offer 4-hour waiting period if 24/7 MDR is in place.

Decision Rationale

Why the Harborline Cyber Protection Policy is built the way it is

COMPANION DOCUMENTS

Specimen policy HIC-CY-100 with Declarations · Sample application
HIC-CY-APP

SAMPLE INSURED

Cedar Ridge Accounting Group, LLC
(fictional)

DATE

September
2026

The short version

I designed a single cyber policy for businesses with roughly \$1M–\$50M in revenue. The goal was that an owner could read it, a broker could sell it, and a claims team could pay it without argument. Five principles drove every decision:

1. **Cover what actually hurts small businesses, at full limits.** Ransomware, business interruption and breach response carry the full \$1M limit. Funds transfer fraud, the most frequent loss, gets a meaningful \$250K.
2. **Make the first 72 hours easy.** One hotline, free incident response that does not reduce the limit, and a one-page “what to do” guide in the Declarations.
3. **Reward security instead of voiding coverage over it.** Good controls earn visible credits. If a control lapses, the terms for that incident revert. The policy does not disappear.
4. **Draw bright lines around systemic risk.** War, infrastructure failure, non-malicious outages and website-tracking suits are excluded or sold as priced options, so the core price stays affordable.
5. **Write for the reader.** Plain English, consistent coverage letters, an “In short” note on every coverage, and definitions that each do one job.

1 How I approached it

Before drafting, I catalogued more than 400 publicly available cyber insurance documents (wordings, specimens, declarations and applications) to see how the market actually handles each design question. I then compared a shortlist of current small-business forms closely: At-Bay, Coalition, Vouch and Corgi's own cyber form, [1–4] backed by Beazley, Crum & Forster, HSB and Chubb forms. [6–9] For each decision I asked three questions:

- **What do the leading forms do, and where do they disagree?** Disagreement marks a real judgment call.
- **What does the loss data say?** I used At-Bay's 2026 InsurSec Report claims data to size limits and retentions. [5]
- **What does the law or regulator require?** Examples are sanctions rules on ransom payments, breach-notification deadlines, war-exclusion standards and the federal terrorism disclosure. [11–16]

I used the NIST Cybersecurity Framework 2.0 to organize the application's security questions, so every underwriting question ties to a recognized control category rather than an insurer's preference. [10]

2 Structure and format

DECISION	WHAT I CHOSE	WHY
One form, core plus options	12 core coverages (A–L) always included; 6 optional (M–R) switched on in the Declarations	At-Bay and Coalition bundle everything; Corgi and Vouch are more modular. [1–4] A hybrid keeps the biggest small-business risks covered by default, so nobody is underinsured by accident, while still letting buyers add niche cover. Everything lives in one form, rather than the 20+ endorsements At-Bay's issued policy carried. [1]
Two triggers	Liability (I–L, Q): claims-made and reported. First-party (A–H, M–P, R): discovered during the policy period.	Lawsuits can arrive years after a breach, so liability needs a claims-made trigger with a retroactive date to keep the insurer's exposure definite. First-party losses are known when discovered, so a discovery trigger is simpler and fairer. This matches the leading forms. [2, 6, 7]
Organized around the reader's questions	Section I What we cover · II Definitions · III What we don't · IV How much · V What to do · VI Other rules	An owner reading during an incident is asking “am I covered, what do I pay, what do I do now?” The contents page maps those questions to sections, and coverage letters are identical in the Declarations and the form.
Plain English with “In short” notes	Short sentences, “you/we”, a one-line summary above each coverage	Clarity is the first thing a small buyer notices. Coalition and At-Bay state the same warnings in all-caps legalese. I kept legal precision in the clauses and added summaries for navigation.
Admitted insurer	Filed, admitted form in Colorado	Coalition writes on admitted paper; At-Bay and Vouch mostly write surplus lines. [1–3] Admitted status gives a regulator-reviewed form and state guaranty fund protection, both of which matter to small businesses.

TRADE-OFF Plain-English summaries can be used against an insurer if a court finds the summary and the clause inconsistent. I kept the summaries short and descriptive, and Section VI.U says they are not contract terms. Admitted paper also means slower rate and form changes than surplus lines, which I accepted for the trust it creates.

3 How I structured the definitions

The definitions follow four rules: one concept per definition; alphabetical and numbered so cross-references are unambiguous; no chains of nested definitions where I could avoid them; and “including” always means a non-exhaustive list. The decisions that matter most:

DEFINITION	CHOICE	REASONING
“Incident” (Def. 28)	One umbrella term for every first-party event	One word lets a single trigger, a single retention rule (“one retention per incident”) and a single related-events rule work across all first-party coverages. Without it, each coverage needs its own mechanics and gaps appear between them.
“Discover” and “Executive” (Defs. 19, 20)	The clock starts when a partner, officer or IT lead knows	A junior employee's vague suspicion should not start the reporting clock or trigger the prior-knowledge exclusion. Small businesses outsource IT, so for knowledge and reporting purposes “Executive” also includes an outsourced IT lead, without making that provider an insured. (Otherwise an attack on the insured's own IT provider could fall outside Coverage E.)
“Security Failure” (Def. 59)	Expressly includes use of stolen or deceived credentials	Most small-business intrusions start with phished passwords. Saying so closes the argument that a login with valid credentials was “authorized.”

DEFINITION	CHOICE	REASONING
"Privacy Event" (Def. 47)	Any unauthorized disclosure, including paper records and employee mistakes	Many small-business breaches are not hacks: a lost laptop, a misdirected email of tax returns. Notification law applies either way, so coverage should too.
"Computer System" (Def. 9)	Includes employee devices used for work; includes vendor-hosted systems (such as hosted email) for every coverage except business interruption and hardware	Data in a cloud app is still your data, and a hacked hosted mailbox is still your security failure. For business interruption, though, I kept your own systems (Coverage D) separate from a vendor's (Coverage E), so the correlated cloud-outage risk can carry its own sublimit.
"Deepfake" and "Social Engineering Fraud" (Defs. 16, 62)	AI-generated voice and video named explicitly	Impersonation by cloned voice or video is the fastest-growing fraud vector. Naming it removes doubt that it is covered.
"Callback Verification" (Def. 6)	Precise and auditable: a number on file or independently obtained, never one from the request, and recorded	The \$100K fraud cap turns on this definition, so it must be objective. Both sides can tell afterwards whether it was done.
"Period of Restoration" (Def. 44)	Until systems are restored and income recovers, capped at 180 days	Income does not recover the moment systems do; clients return gradually. The cap keeps the exposure finite.

4 Limits, retentions and sublimits

The numbers below are sized to At-Bay's 2026 small-business claims data [\[5\]](#) and set against what the benchmark forms offer. [\[1-4\]](#)

TERM	CHOICE	REASONING
Policy aggregate limit	\$1,000,000	At-Bay's and Coalition's small-business policies both used \$1M. The average claim for firms under \$25M revenue was about \$180K, and the average ransomware claim about \$508K. [5] \$1M covers a severe ransomware event with room for the liability claims that follow it (see Example 1).
Retention	Scaled by revenue: \$10,000 for \$5M–\$25M, cut to \$5,000 with security credits	At-Bay and Coalition use \$2,500, which fits micro-businesses. Vouch and Corgi use \$10,000, which fits mid-sized firms. Scaling by revenue covers the whole \$1M–\$50M market, and the credit rewards controls that reduce loss.
One retention per incident	Only the largest retention applies	A ransomware attack can trigger six coverages. Stating on the Declarations that the business pays once prevents the "three deductibles?" shock.
Incident response (A)	First 72 hours outside the limit, \$0 retention	Borrowed from Coalition. [2] Early expert help is the cheapest loss control there is. If calling costs nothing, owners call sooner. The 72-hour window and panel rates keep the insurer's cost bounded.
Ransomware, BI, restoration (C, D, F)	Full \$1M limit	These are the severe losses. Vouch's \$62,500 ransomware sublimit [3] sits far below the ~\$508K average ransomware claim. [5]

TERM	CHOICE	REASONING
Dependent BI (E)	\$500,000	Vendor-caused events were about 14% of At-Bay's claims. [5] One cloud outage can hit thousands of insureds at once, as the July 2024 CrowdStrike outage showed. Half the limit balances real protection against that accumulation risk; At-Bay offers \$1M, Vouch \$25K.
Fraud (H)	\$250,000; \$500,000 option (R)	Covers the ~\$208K average fraud loss for firms under \$25M; the option serves firms nearer the ~\$373K average in the \$25M–\$100M band. [5]
Fraud retention incentive	\$2,500 instead of \$5,000 if reported within 72 hours	Speed decides recovery: about 70% of fraud victims who reported within 3 days recovered some money, against 27% after 30 days. [5] A lower retention pays owners to report fast, which also reduces our loss.
BI waiting period and restoration period	8 hours; up to 180 days	8 hours is the market norm. [1–3] 180 days matches At-Bay and Coalition. Vouch's 90 days is too short when about 1 in 10 ransomware cases causes 30+ days of downtime and income takes longer still to recover. [5]
PCI (K), security improvements (G)	\$250,000; \$25,000	Most small businesses take cards through hosted pages, so PCI exposure is modest. Coverage G is small but closes the loop: the attack that happened once is the attack most likely to happen again.
Extended reporting	60 days automatic; 12 months at 75% or 24 months at 125%	Priced like At-Bay [1] and cheaper than Coalition's 100% / 150% / 200%, which is fairer for a small business closing or switching carriers.

5 What I included, made optional or left out

Core coverages (A–L)

Every core coverage answers a loss that small businesses report regularly: breach response and notification, extortion, downtime, data restoration, payment fraud, and the lawsuits and regulatory inquiries that follow a breach. Media liability is cheap to include and covers a real exposure, since every business now publishes content on its website and social media.

Optional coverages (M–R), and why each is optional

OPTION	WHY OPTIONAL RATHER THAN CORE
M · System failure BI	Non-malicious outages (a bad update, an IT error) are frequent and correlated: one vendor update can take down thousands of customers at once. Pricing it separately keeps the core affordable and lets firms that depend heavily on uptime buy it.
N · Bricking	Relevant mainly to firms with on-site hardware. Cedar Ridge bought it for its laptop fleet.
O · Reputational harm	Lost-profit-from-publicity is hard to measure for a small business and invites disputes about causation. It makes sense as an option for consumer-facing brands.
P · Cryptojacking and telecom fraud	Small, specific losses. Cheap to add for firms with cloud accounts or VoIP systems.
Q · Website tracking liability	Lawsuits over pixels and session replay under the California Invasion of Privacy Act and similar laws are concentrated in businesses that run advertising pixels. The application asks about tracking tools (Q. 4.5), so only the firms that need it pay for it.
R · Higher fraud limit	For firms with larger payment flows. It keeps the base price right for everyone else.

Left out entirely

- **Professional errors (E&O).** Exclusion III.A.11 keeps cyber and professional liability cleanly separate. A tax-preparation mistake belongs on an accountant's E&O policy, but a claim that a breach exposed a client's data stays covered here.

- **Biometric privacy suits.** Illinois's Biometric Information Privacy Act sets statutory damages of \$1,000 to \$5,000 per violation, [15] which creates liability out of proportion to a small-business premium. Theft of biometric data by a hacker is still covered.
- **Robocall and spam law (TCPA).** Marketing-practice risk rather than cyber risk.
- **Bodily injury, property damage and physical perils.** These belong to general liability and property policies. Coverage N is the one deliberate exception, for bricked hardware.

6 The exclusion decisions that took the most judgment

War and state-backed cyber operations (III.A.5)

Since March 2023 Lloyd's has required standalone cyber policies to exclude state-backed cyber attacks, and the Lloyd's Market Association published model clauses for doing so. [12] The NotPetya litigation, in which a court refused to apply a traditional war exclusion to a cyberattack, showed that vague wording helps no one. [17] I followed the model-clause structure but added three protections for the insured: the exclusion applies only to operations with a major impact on a state's essential services or security; systems outside the impacted state are carved back in; and the insurer carries the burden of proof, with a defined attribution process.

Infrastructure failure (III.A.6)

Widespread power or internet-backbone failures cannot be priced into a small-business premium. The exclusion states that a cloud or IT vendor is not “infrastructure,” so it cannot be used to deny a legitimate Coverage E claim.

Other lines I drew deliberately

- **Prior knowledge** turns on what an *Executive* knew before the continuity date, not on what anyone in the business might have known.
- **Intentional acts** apply only after a final ruling or admission. We defend until then, and a rogue employee's acts do not remove cover for the business.
- **Contractual liability** carves back confidentiality obligations and PCI terms. Small businesses routinely sign NDAs, business associate agreements and merchant agreements that promise data security.
- **Betterment** is excluded, except for the capped Coverage G upgrades and like-for-like hardware replacement under Coverage N.

7 Conditions: making it work in practice

CONDITION	CHOICE	REASONING
Security credit adjustment (IV.G)	If a credited control is missing when an incident starts, that incident reverts to un-credited terms	This is the most distinctive choice in the policy. Many forms exclude or void coverage for “failure to maintain” a represented control. That is harsh on small businesses whose controls lapse briefly, and it invites coverage fights. Reverting the specific credit (retention, ransomware coinsurance or fraud limit) keeps the incentive and keeps the business insured. Rescission is reserved for intent to deceive.
Legal notices never need consent (V.D)	Stated in the policy, the Declarations and the incident guide	Colorado requires notice to affected residents within 30 days, [14] and the FTC Safeguards Rule now requires tax preparers and similar firms to notify the FTC of breaches affecting 500 or more people. [13] An insured should never have to choose between the law and their coverage.

CONDITION	CHOICE	REASONING
Ransom payments (V.F)	Consent, sanctions screening, law-enforcement reporting where asked, and confirmation that restoring from backups is not a reasonable alternative	Tracks the Treasury (OFAC) advisory on ransomware payments. [11] Paying is always the insured's decision; we never require it.
Panel providers (V.C)	Panel use needs no consent; outside providers at panel rates; emergency costs covered if reported within 48 hours	Speed first, with cost control, and without trapping an insured who already has a trusted provider.
Settlement (V.H)	Duty to defend; soft "hammer" (70/30 split after a refused settlement)	Small businesses have no in-house counsel, so the insurer should defend. A soft hammer discourages unreasonable refusals without forcing a settlement on the insured.
Late notice (V.A)	Claims: firm 60-day post-period deadline. Incidents: late notice denied only if it caused real prejudice.	Claims-made coverage needs a firm reporting deadline to work. For first-party losses, a prejudice test is fairer and reflects how most courts approach late notice.
Small-business-friendly terms	Pro rata refunds on cancellation; automatic broadening (VI.R); optional risk services that never affect coverage	Each costs little and signals good faith, which matters when the buyer is not an insurance professional.

8 How it works in practice: three worked examples

All three use the sample insured, Cedar Ridge Accounting Group (Declarations: \$1M aggregate, \$5,000 retention, 8-hour waiting period, all three credited controls in place). Dollar figures are illustrative.

Example 1 · Ransomware in the middle of tax season

At 7:00 a.m. on a Monday in March, staff find files encrypted and a note demanding \$400,000 and threatening to publish stolen client data. Marcus Lee calls the hotline. The breach coach and forensic team are working remotely within the hour (Coverage A). Tested backups mean restoring is realistic, so, after negotiators assess the leak threat, Cedar Ridge decides not to pay. Systems are back by Friday. Forensics confirms that files covering 6,200 clients were copied. Colorado's attorney general opens an inquiry, and a class action follows five months later.

COVERAGE	WHAT IS PAID	AMOUNT
A · Incident response	Breach coach and forensic triage, first 72 hours (outside the limit, no retention)	\$38,000
B · Breach response	Further forensics and legal advice, notices and call center for 6,200 people, credit monitoring, PR	\$166,500
C · Extortion	Negotiator's threat assessment (no ransom paid)	\$9,500
D · Business interruption	Lost billings after the 8-hour waiting period (\$360,000), less work recovered in April (– \$180,000) and saved costs (–\$10,000); plus overtime and temporary staff (\$28,000) and a forensic accountant (\$6,000)	\$204,000
F · Restoration	Rebuilding systems and restoring data	\$46,000
G · Security improvements	24/7 MDR for a year and hardening the forensic team recommended (capped)	\$25,000
J · Regulatory	Defense of the attorney general inquiry (no penalty imposed)	\$28,000
I · Privacy liability	Class action defense (\$95,000) and settlement (\$150,000)	\$245,000
Loss within limits \$724,000 – one \$5,000 retention = Harborline pays \$719,000, plus \$38,000 of Coverage A outside the limit		\$719,000

Cedar Ridge pays \$5,000 and absorbs the first 8 hours of downtime; \$281,000 of the aggregate limit remains for the rest of the year. **Why the credits matter:** without the backup credit, 20% ransomware coinsurance would have cost Cedar Ridge about \$143,800 more. Without the MFA/EDR credit, the retention would have been \$10,000.

Example 2 · Two kinds of payment fraud

(a) Funds transfer fraud. Criminals steal online-banking access and wire \$148,000 out overnight. Cedar Ridge notices the next morning and calls its bank and the hotline within 6 hours. The bank recalls \$40,000. **Direct financial loss \$108,000, less the reduced \$2,500 retention (reported within 72 hours): Harborline pays \$105,500.** The callback rule does not apply, because nobody at Cedar Ridge was tricked into sending the money.

(b) Social engineering with a deepfake. An email and a follow-up call in a cloned voice of the landlord's property manager “update” the bank details for the \$62,400 rent payment. The clerk skips the callback, and Cedar Ridge reports the fraud the next day. Because the loss is under the \$100,000 cap, Harborline still pays \$59,900. Had the fraud diverted \$180,000, the missed callback would cap payment at \$100,000 instead of \$177,500. The cap costs nothing on everyday losses and bites only on large ones, which are exactly the losses a two-minute phone call prevents.

Example 3 · Where coverage deliberately stops

EVENT	RESULT	WHY
The cloud tax platform is hit by ransomware during filing week; Cedar Ridge loses \$150,000 of income over 3 days	Covered under E: \$150,000 (waiting period only, no dollar retention)	A security failure at a dependent business
A faulty security-software update crashes Cedar Ridge's own laptops for 2 days	Not covered	A non-malicious system failure needs optional Coverage M, which Cedar Ridge declined
The tax platform goes down because of its own coding error	Not covered	A non-malicious outage at a vendor is the most correlated cyber risk; no coverage in this form responds to it

Being explicit about these edges is intentional. A buyer should learn what is not covered from the policy and the application, not from a claim denial.

9 Trade-offs I weighed, and what I would do next

Alternatives I considered and rejected

- **Notification costs outside the limit** (Beazley's per-person approach [\[6\]](#)). This protects the limit in a large breach, but a small business struggles to understand it, and it adds pricing complexity. It is a candidate future option.
- **A flat ransomware sublimit or coinsurance for everyone.** I used coinsurance only where the backup control is missing, which targets the risk rather than penalizing good insureds.
- **A separate, higher fraud retention.** I chose the single retention plus the fast-reporting discount, which gives a better incentive and is simpler.
- **Reimbursement instead of a duty to defend.** This is cheaper for the insurer, but it leaves small businesses managing litigation they are not equipped for.

What a real launch would still need

- Actuarial pricing and rate filings, with state amendatory endorsements for each state (the Colorado endorsement is listed but not drafted here).
- Accumulation modelling and reinsurance for the correlated exposures: Coverages E and M, and the war-exclusion boundary.
- Panel provider contracts and rates, and claims-handling guidelines for the 72-hour service.
- Readability testing of the form and Declarations with real small-business owners, and review of the “In short” notes with regulators during filing.
- A decision on whether to add dependent-business system failure as a priced option, the gap shown in Example 3.

10 References

1. At-Bay. Issued cyber insurance policy (ASTRO America), 2025–26 policy term.
2. Coalition. Cyber Policy 3.0 (Active Cyber Policy), issued policy, 2025–26 policy term.
3. Vouch. Cyber insurance policy declarations, 2025–26 policy term.
4. Corgi. Cyber Liability policy form CORG-CY-0100.

5. At-Bay. *The 2026 InsurSec Report*. April 2026.

6. Beazley. Beazley Breach Response specimen policy form F00653 (02/2025). portal.bigimd.com/files/Membership%20Benefits/Cyber%20Liability%20Insurance/Beazley_SpecimenPolicyForm.pdf

7. Crum & Forster. Simple Cyber policy form, Version 6.0 (September 4, 2025). cfins.com/wp-content/uploads/2021/05/Simple-Cyber-General-v6-2025.09.04.pdf

8. HSB (Munich Re). Cyber Suite Coverage Form CSC (02-2025), as filed by Heartland Mutual Insurance. heartlandmutualinsurance.com/wp-content/uploads/2024/12/Cyber-Suite-Coverage-Form-CSC-02-2025.pdf

9. Chubb. Cyber Enterprise Risk Management small business specimen, PF-48169 (02/19). studio.chubb.com/connect/files/NA_CyberSmallBusiness_Sample.pdf

10. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29. February 2024. doi.org/10.6028/NIST.CSWP.29

11. U.S. Department of the Treasury, Office of Foreign Assets Control. *Updated Advisory on Potential Sanctions Risks for Facilitating Ransomware Payments*. September 21, 2021.

12. Lloyd's. Market Bulletin Y5381, "State backed cyber-attack exclusions," August 2022; Lloyd's Market Association model clauses LMA5564–LMA5567, November 2021.

13. Federal Trade Commission. Standards for Safeguarding Customer Information (Safeguards Rule), 16 C.F.R. Part 314, as amended; FTC breach-notification requirement effective May 13, 2024.

14. Colorado Revised Statutes §§ 6-1-713.5 (protection of personal identifying information) and 6-1-716 (notification of security breach).

15. Illinois Biometric Information Privacy Act, 740 ILCS 14/20 (statutory damages).

16. Terrorism Risk Insurance Act of 2002, as amended and extended by the Terrorism Risk Insurance Program Reauthorization Act of 2019.

17. *Merck & Co. v. ACE American Insurance Co.*, N.J. Super. Ct. App. Div. (2023) (war exclusion held inapplicable to the NotPetya cyberattack).

A Appendix: Declarations design log

My working notes from designing the Declarations page. Each element takes the strongest idea from a benchmark policy and adapts it for small businesses.

WHAT I CHOSE	BORROWED FROM	WHY IT IS BETTER
Numbered items (Item 1, 2, 3...)	Coalition	Cleanest structure of the pages reviewed; easy to reference ("see Item 7")
Plain-English notices at the top	Coalition's content, rewritten	The same warnings, without the all-caps legalese
"What it pays for" column	Corgi's plain-English style	An owner understands each coverage at a glance, on the Declarations itself
Security credits table	Coalition and At-Bay approaches	Shows exactly what was earned, and what is still available (MDR), on the page
Full prior acts plus continuity date	Coalition	Broad cover while still excluding problems already known
Three reporting channels plus legal-notice line	Coalition, plus regulatory research	Easy reporting; protects businesses facing 30-day state breach deadlines
Short forms list	Improvement on At-Bay	Optional coverages live in one form, not 20+ endorsements
Incident roadmap back page	At-Bay	Makes the Declarations useful in a crisis, not just paperwork